



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temas Específicos para la preparación de la Oposición al Cuerpo
Superior de Sistemas y Tecnologías de la Información de la
Administración del Estado.

TEMAS ESPECÍFICOS II: Tecnología básica

Tema 80. Identificación y firma electrónica (1) Marco europeo y nacional. Certificados digitales. Claves privadas, públicas y concertadas. Formatos de firma electrónica. Protocolos de directorio basados en LDAP y X.500. Otros servicios

AUTOR: María Teresa Avelino Carmona

Actualización 2017

ÍNDICE

1	INTRODUCCIÓN	4
2	CONTROL DE LA IDENTIDAD DE LOS USUARIOS	5
2.1	IDENTIFICACIÓN.....	5
2.2	AUTENTICACIÓN.....	5
2.3	AUTORIZACIÓN.....	7
2.4	AUDITORÍA	7
2.5	IDENTIFICACIÓN DE LOS CIUDADANOS EN LOS PROCEDIMIENTOS	7
2.5.1	VERIFICACIÓN DE LA IDENTIDAD DE LOS INTERESADOS	8
2.6	IDENTIFICACIÓN DE LAS ADMINISTRACIONES PÚBLICAS.....	8
2.6.1	SEDE ELECTRÓNICA	9
2.6.2	ACTUACIÓN ADMINISTRATIVA AUTOMATIZADA.....	10
2.6.3	IDENTIFICACIÓN MEDIANTE EL PERSONAL AL SERVICIO	10
2.7	CONTROLES ESTABLECIDOS EN EL ENS	10
3	FIRMA ELECTRÓNICA	11
3.1	DEFINICIÓN DE FIRMA ELECTRÓNICA	11
3.2	FIRMA DE LOS INTERESADOS EN LOS PROCEDIMIENTOS ADMINISTRATIVOS	12
3.2.1	OBLIGATORIEDAD DE LA FIRMA EN PROCESOS ADMINISTRATIVOS	13
3.3	FIRMA DE MÚLTIPLES USUARIOS CO-FIRMA Y CONTRAFIRMA	13
3.4	FIRMA Y SELLO DE LAS ADMINISTRACIONES PÚBLICAS	14
3.5	CÓDIGO SEGURO DE VERIFICACIÓN (CSV)	14
3.6	SELLADO DE TIEMPO	15
3.6.1	RESELLADO	15
4	LEGISLACIÓN EUROPEA Y NACIONAL DE FIRMA ELECTRÓNICA	16
4.1	REGLAMENTO EUROPEO DE IDENTIFICACIÓN Y LEGISLACIÓN AFÍN UE	16
4.1.1	NOVEDADES DEL REGLAMENTO	16
4.1.2	BREVE RESUMEN DEL CONTENIDO DEL REGLAMENTO	17
4.1.3	NIVELES DE SEGURIDAD DE LOS SISTEMAS DE AUTENTICACIÓN	19
4.1.4	NUEVOS SERVICIOS DE CONFIANZA.....	20
4.2	LEGISLACIÓN NACIONAL.....	24
4.2.1	LEY DE FIRMA	24
4.2.2	ESQUEMA NACIONAL DE INTEROPERABILIDAD	25
4.2.3	NORMA TÉCNICA DE INTEROPERABILIDAD DE POLÍTICA DE FIRMA Y SELLO ELECTRÓNICOS Y DE CERTIFICADOS DE LA ADMINISTRACIÓN	25
4.2.4	LA POLÍTICA DE FIRMA ELECTRÓNICA DE LA AGE	25
4.2.5	FUTURA LEY DE SERVICIOS DE CONFIANZA	26

4.2.6	ESQUEMA NACIONAL DE SEGURIDAD	26
5	CERTIFICADOS DIGITALES	28
5.1	CERTIFICADOS DE SERVIDOR X.509V3 PARA AUTENTICACIÓN WEB	28
5.1.1	SOLICITUDES DE CERTIFICADOS.....	31
5.2	CERTIFICADOS DE FIRMA.....	31
5.2.1	ESTÁNDAR X509 PARA CERTIFICADOS DE FIRMA	32
5.3	CERTIFICADOS DE SELLO	32
5.3.1	CERTIFICADOS CUALIFICADOS DE SELLO	32
5.4	COMPROBACIÓN DEL ESTADO DE LOS CERTIFICADOS	32
6	CLAVES PÚBLICAS, PRIVADAS Y CONCERTADAS	34
6.1	PROCEDIMIENTO CRIPTOGRÁFICO DE FIRMA ELECTRÓNICA	34
6.2	CLAVES CONCERTADAS	35
6.2.1	PIN24H	35
6.2.2	CL@VE.....	35
7	FORMATOS DE FIRMA ELECTRÓNICA	37
7.1	FORMATOS DE FIRMA MÁS COMUNES	37
7.1.1	CADES (CMS AVANZADO).....	37
7.1.2	XADES (XML AVANZADO)	37
7.1.3	PADES (PDF AVANZADO).....	37
7.1.4	OOXML Y ODF	38
7.2	FIRMAS LONGEVAS Y FORMATOS.....	38
7.3	FIRMAS ATTACHED, DETACHED, ENVELOPED, ENVELOPING	39
7.4	FORMATOS ADMITIDOS POR LAS AAPP Y REGLAMENTO E IDAS	39
8	PROTOCOLOS DE DIRECTORIO BASADOS EN LDAP Y X.500	41
8.1	X.500. ARQUITECTURA Y MODELO DE INFORMACIÓN.....	41
8.1.1	ARQUITECTURA.....	41
8.1.2	MODELO DE INFORMACIÓN	42
8.1.3	PROTOCOLOS	42
8.1.4	RELACIÓN ENTRE X.500 Y LOS CERTIFICADOS DIGITALES X.509	42
8.2	LDAP	43
8.2.1	USO DEL PROTOCOLO: QUERIES	43
8.2.2	MODELO DE INFORMACIÓN	44
8.2.3	ARQUITECTURA.....	44

1 Introducción

En el contexto actual de la Sociedad de la Información, la identidad de los individuos se manifiesta a través de sus interacciones digitales, mediante la constitución de avatares en juegos online, perfiles en redes sociales, y, en general, una serie de actuaciones y rastros que dejan las personas al interactuar en los diferentes sitios de Internet a los que acceden y con los que interactúan.

El problema es que Internet, por lo general, no es capaz de detectar las falsedades e impostaciones de la identidad, y en muchos casos, al dueño del sitio no tiene la capacidad o no le interesa realizar comprobaciones exhaustivas. Habitualmente oímos noticias de personas que han cometido delitos haciéndose pasar por otras personas o creando perfiles falsos.

Las redes sociales, incluso las más populares, están a menudo plagadas de perfiles impostores o de personas que mienten o maquillan sus atributos físicos, profesionales o de cualquier índole dado que es difícil y a menudo poco rentable que el sitio web compruebe todo lo que los usuarios describen de sí mismos.

Parece, por tanto, que muchos sitios web dejan la protección de la identidad de sus usuarios al albur de la protección que puedan ofrecer a posteriori las autoridades para perseguir los delitos que atenten contra ella.

En determinados servicios dedicados al comercio electrónico o a servicios de banca online, los controles de la identidad se realizan con bastante rigor.

Y como no podría ser de otra manera, la relación de los ciudadanos con la Administración a través de Internet no podría por menos que realizarse con una serie de garantías y mecanismos de control rigurosos en cuanto a la identidad tanto de las personas que acceden como de la propia Administración manifestada en forma digital.

En este tema nos ocuparemos tanto del control de la identidad de los ciudadanos, como de la de la identidad de las sedes electrónicas y sitios web de la Administración.

Los detalles del uso del DNI electrónico como medio tanto de identificación y autenticación como de firma, así como otro tipo de tarjetas inteligentes y el servicio de @Firma se verán en el próximo tema.

2 Control de la identidad de los usuarios

Antes de avanzar con contenidos más complejos, es preciso fijar una serie de conceptos fundamentales que son esenciales tanto para este tema como para el próximo. En el próximo tema 78, en el tema 119 de seguridad de las redes, en el apartado de control de acceso, así como en los específicos de cada sistema operativo se profundizarán los mecanismos que aquí se exponen.

El concepto de Autenticación es crucial para garantizar la identidad de los ciudadanos en su acceso a los servicios por vía electrónica que ofrece la Administración.

El proceso completo de gestión de acceso a un sistema (llamado también como proceso de autenticación) comprende los siguientes pasos:

- **Identificación**
- **Autenticación**
- **Autorización**
- **Auditoría**

En la jerga de seguridad se encuentra a menudo denotado como AAA (Autenticación, Autorización y Auditoría).

2.1 Identificación

La Identificación es el primer paso de la Autenticación. Consiste en la presentación de las credenciales ante el mecanismo de control de acceso del sitio al que se quiere acceder y la comprobación de que el **identificador** es válido. (El equivalente en el mundo analógico sería, por ejemplo, la presentación del DNI o documento de identificación físico a la persona que está en el control de acceso a un edificio).

En el mundo digital se corresponde, por ejemplo, con la introducción del login en la ventana de credenciales que muestra un sitio web.

El identificador que se presenta al sistema (conocido también como login) **debe ser único para cada usuario que accede al sistema.**

El identificador es una cadena alfanumérica que se presenta al sistema. Previamente a la identificación, el usuario debe estar dado de alta en el sistema mediante un procedimiento previo de Registro de Usuarios.

2.2 Autenticación

Pero la autenticación precisa no sólo de la comprobación de que el identificador sea válido sino de la verificación de que la persona que nos presenta ese identificador correcto es quién dice ser, por lo que se le somete a un desafío que nos proporcione confianza sobre dicha identidad.

Para realizar esa verificación se pueden utilizar diversos mecanismos en función del grado de rigurosidad que sea preciso emplear lo cual irá asociado a la categoría (ENS) del sistema al que se pretende acceder, teniendo en cuenta los requisitos y categoría en la dimensión de seguridad Autenticidad.

El mecanismo de control más habitual es el de la contraseña (algo que el usuario conoce), como en la imagen que se muestra en la siguiente página.

Los mecanismos para realizar la autenticación de los usuarios se dividen en:

- El uso de algo que el usuario conoce (o debería conocer si es quien dice ser) como es el caso de la contraseña.

- El uso de algo que el usuario posee (o debería tener en teoría si es quien dice ser (por ejemplo, su móvil, una tarjeta de coordenadas, el DNI electrónico, un correo electrónico, etc.)
- El uso de algo que el usuario es o hace (características), como por ejemplo la voz, el iris, la huella dactilar, etc.

Figura 1: Ventana de ejemplo de control de acceso un sitio web tomado de la wikipedia

La autenticación simple utiliza sólo uno de estos métodos de autenticación, la típica es la contraseña. **La autenticación doble** utiliza otro factor adicional para comprobar la identidad de la que persona que accede, por ejemplo, una clave recibida por SMS al móvil, la huella dactilar, una coordenada de la tarjeta de coordenadas personal entregada por el banco (por ejemplo, cuando queremos hacer una transferencia se utiliza como segundo factor por seguridad, aunque ya estemos logados previamente con contraseña en el sistema de banca electrónica).

La robustez de un sistema de autenticación no sólo depende del número de factores que incluya sino también de la calidad de los controles empleados para implementar cada factor.

Por ejemplo, un sistema que sólo pida una contraseña de cuatro números y el usuario además establezca como su contraseña la típica 1234 podrá ser objeto de ataques “por fuerza bruta”, que consisten en que el atacante prueba con todos los valores posibles hasta que encuentra el correcto.

Además de usar contraseñas robustas (suficientemente largas y que incluyan letras, números, mayúsculas y minúsculas y caracteres especiales), deben contar los sistemas con controles que detecten y prevengan los ataques de fuerza bruta (por ejemplo, demorar el intento de nuevo login cuando se haya fallado la vez anterior o bloquear el usuario impidiendo nuevos intentos si se han fallado cierto número de veces, por ejemplo 5).

Es preciso controlar los accesos remotos, aquellos que se realizan desde fuera de las organizaciones usando habitualmente Internet como medio para el acceso. Si se accede a una organización a través de Internet se recomienda el uso autenticación de doble factor como mínimo.

A veces, algunas organizaciones utilizan **Single Sign On** como mecanismo de autenticación común para aplicaciones que no requieren permisos especiales de acceso.

Este mecanismo supone que es el Sistema Operativo o un Gestor común de Contraseñas el que se encarga de inyectar un ticket con la información de las credenciales validadas a la aplicación que las solicita, de modo que el usuario no debe introducir sus credenciales en cada aplicación a la que intenta acceder dentro de un sistema. Por ejemplo, la Intranet de una organización.

No obstante, cuando la aplicación sea sensible, será preciso que el usuario introduzca un segundo factor de autenticación para permitirle el acceso. Por ejemplo, en la aplicación de la Intranet que gestiona las vacaciones de los empleados podría pedir un segundo factor o la introducción físicamente de la tarjeta de empleado en el lector de tarjetas.

2.3 Autorización

La **Autorización**, una vez que la autenticación se ha realizado con éxito, establece qué permisos le corresponden al usuario que se autenticado en el sistema. Por ejemplo, a qué aplicaciones podrá acceder, qué repositorios de información podrá utilizar, etc.

Tan importante como verificar la identidad de los usuarios es el establecer correctamente los privilegios y disponer de mecanismos que eviten que los usuarios puedan elevar indebidamente sus privilegios en el sistema al que han accedido (ataque de elevación de privilegios).

2.4 Auditoría

Por último, la **Auditoría** debe recoger la información requerida respecto al acceso de los usuarios a los sistemas tales como qué identificador se usó para acceder, desde donde accedió (terminal local o remoto), recursos a los que ha accedido, si ha elevado sus privilegios, etc.

Esta información se deberá analizar para encontrar patrones sospechosos que puedan indicar que un usuario pueda haber sido suplantado o bien que haya accedido indebidamente a recursos a los que no debería tener acceso.

2.5 Identificación de los ciudadanos en los procedimientos

Derogada ya la Ley 11/2007, la **Ley 39/2015** recoge en su **Capítulo II** las condiciones para verificar la identidad y firma de los interesados en un procedimiento administrativo común (PAC).

La Ley 39/2015 establece en el artículo 11.1 lo siguiente:

1. Con carácter general, para realizar cualquier actuación prevista en el procedimiento administrativo, será suficiente con que los interesados acrediten previamente su identidad a través de cualquiera de los medios de identificación previstos en esta Ley.

También establece en el artículo 10.4 que, cuando el procedimiento requiera de firma, la firma del interesado servirá también para acreditar la identificación del mismo.

Por último, se establece en el artículo 12.2 último párrafo que los ciudadanos se podrán identificar y firmar mediante la delegación de tal acto en un funcionario habilitado para tal fin:

“...si alguno de estos interesados no dispone de los medios electrónicos necesarios, su identificación o firma electrónica en el procedimiento administrativo podrá ser válidamente realizada por un funcionario público mediante el uso del sistema de firma electrónica del que esté dotado para ello. En este caso, será necesario que el interesado que carezca de los medios electrónicos necesarios se identifique ante el funcionario y preste su consentimiento expreso para esta actuación, de lo que deberá quedar constancia para los casos de discrepancia o litigio.”

2.5.1 Verificación de la identidad de los interesados

El artículo 9 establece las condiciones para verificar la identidad de los interesados en el Procedimiento Administrativo Común:

- 1) Las Administraciones Públicas están obligadas a verificar la identidad de los interesados en el procedimiento administrativo, mediante la comprobación de su nombre y apellidos o denominación o razón social, según corresponda, que consten en el Documento Nacional de Identidad o documento identificativo equivalente.
- 2) Los interesados podrán identificarse electrónicamente ante las Administraciones Públicas a través de cualquier sistema que cuente con un registro previo como usuario que permita garantizar su identidad. En particular, serán admitidos, los sistemas siguientes:

a) Sistemas basados en certificados electrónicos reconocidos o cualificados de firma electrónica expedidos por prestadores incluidos en la «Lista de confianza de prestadores de servicios de certificación». A estos efectos, se entienden comprendidos entre los citados certificados electrónicos reconocidos o cualificados los de persona jurídica y de entidad sin personalidad jurídica.

b) Sistemas basados en certificados electrónicos reconocidos o cualificados de sello electrónico expedidos por prestadores incluidos en la «Lista de confianza de prestadores de servicios de certificación».

c) Sistemas de clave concertada y cualquier otro sistema que las Administraciones Públicas consideren válido, en los términos y condiciones que se establezcan.

Cada Administración Pública podrá determinar si sólo admite alguno de estos sistemas para realizar determinados trámites o procedimientos, si bien la admisión de alguno de los sistemas de identificación previstos en la letra c) conllevará la admisión de todos los previstos en las letras a) y b) anteriores para ese trámite o procedimiento.

- 3). En todo caso, la aceptación de alguno de estos sistemas por la Administración General del Estado servirá para acreditar frente a todas las Administraciones Públicas, salvo prueba en contrario, la identificación electrónica de los interesados en el procedimiento administrativo.

2.6 Identificación de las Administraciones Públicas

La Ley 40/2015 (Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público) establece en su artículo 40 cómo ha de identificarse ante los ciudadanos las Administraciones Públicas:

Artículo 40 Sistemas de identificación de las Administraciones Públicas

1. Las Administraciones Públicas podrán identificarse mediante el uso de un sello electrónico basado en un certificado electrónico reconocido o cualificado que reúna los requisitos exigidos por la legislación de firma electrónica. Estos certificados electrónicos incluirán el número de identificación fiscal y la denominación correspondiente, así como, en su caso, la identidad de la persona titular en el caso de los sellos electrónicos de órganos administrativos. La relación de sellos electrónicos utilizados por cada Administración Pública, incluyendo las características de los certificados electrónicos y los prestadores que los expiden, deberá ser pública y accesible por medios electrónicos. Además, cada Administración Pública adoptará las medidas adecuadas para facilitar la verificación de sus sellos electrónicos.

2. Se entenderá identificada la Administración Pública respecto de la información que se publique como propia en su portal de internet.

De este artículo se infiere el uso los elementos para la identificación:

- Sello electrónico.
- Certificado electrónico de la sede electrónica.

Al que se sumará el de la identificación mediante la firma del personal al servicio.

2.6.1 Sede electrónica

La identidad de las Administraciones Públicas en los procesos administrativos comunes se articula mediante la **Sede Electrónica**, que se regula por la ley 40/2015.

Definición de sede electrónica, artículo 38.1 de la ley 40/2015:

“La sede electrónica es aquella dirección electrónica, disponible para los ciudadanos a través de redes de telecomunicaciones, cuya titularidad corresponde a una Administración Pública, o bien a una o varios organismos públicos o entidades de Derecho Público en el ejercicio de sus competencias.”

La sede electrónica se erige por tanto como el sitio web por el que los interesados/ciudadanos acceden a los servicios que ofrece el titular de la misma. Utilizar para la confidencialidad de las comunicaciones un certificado de sitio web de los que veremos en el capítulo 5, y conlleva una serie de responsabilidades respecto a la seguridad, accesibilidad, interoperabilidad y verificación de la identidad de la misma.

El artículo 38 apartados 2 y 3 de esta Ley (40/2015) regula las condiciones de seguridad que deben cumplir dichas sedes:

“2. El establecimiento de una sede electrónica conlleva la responsabilidad del titular respecto de la integridad, veracidad y actualización de la información y los servicios a los que pueda accederse a través de la misma.

3. Cada Administración Pública determinará las condiciones e instrumentos de creación de las sedes electrónicas, con sujeción a los principios de transparencia, publicidad, responsabilidad, calidad, seguridad, disponibilidad, accesibilidad, neutralidad e interoperabilidad. En todo caso deberá garantizarse la identificación del órgano titular de la sede, así como los medios disponibles para la formulación de sugerencias y quejas.”

El apartado 6 de este mismo artículo 38 indica que estas sedes electrónicas deben usar para su identificación certificados reconocidos o cualificados (ver en el próximo capítulo la referencia a eIDAS):

“6. Las sedes electrónicas utilizarán, para identificarse y garantizar una comunicación segura con las mismas, certificados reconocidos o cualificados de autenticación de sitio web o medio equivalente.”

2.6.2 Actuación administrativa automatizada

El artículo 41 de la Ley 40/2015 prevé la actuación administrativa automatizada y su firma en el procedimiento en cuestión mediante el sello electrónico correspondiente que se define en el artículo 42 y que veremos en detalle en el capítulo 3 dedicado a la firma:

“1. Se entiende por actuación administrativa automatizada, cualquier acto o actuación realizada íntegramente a través de medios electrónicos por una Administración Pública en el marco de un procedimiento administrativo y en la que no haya intervenido de forma directa un empleado público.

2. En caso de actuación administrativa automatizada deberá establecerse previamente el órgano u órganos competentes, según los casos, para la definición de las especificaciones, programación, mantenimiento, supervisión y control de calidad y, en su caso, auditoría del sistema de información y de su código fuente. Asimismo, se indicará el órgano que debe ser considerado responsable a efectos de impugnación.”

2.6.3 Identificación mediante el personal al servicio

La Ley 40/2015 prevé en el artículo 43: “Firma electrónica del personal al servicio de las Administraciones Públicas” que pueda ser un funcionario competente para el procedimiento en cuestión quien firme en nombre del órgano u organismo al que representa:

1. Sin perjuicio de lo previsto en los artículos 38, 41 y 42, la actuación de una Administración Pública, órgano, organismo público o entidad de derecho público, cuando utilice medios electrónicos, se realizará mediante firma electrónica del titular del órgano o empleado público.

2. Cada Administración Pública determinará los sistemas de firma electrónica que debe utilizar su personal, los cuales podrán identificar de forma conjunta al titular del puesto de trabajo o cargo y a la Administración u órgano en la que presta sus servicios. Por razones de seguridad pública los sistemas de firma electrónica podrán referirse sólo el número de identificación profesional del empleado público.

2.7 Controles establecidos en el ENS

Para concluir este capítulo, es preciso remarcar que El Esquema Nacional de Seguridad, en su Anexo II nos presenta una serie de controles y mecanismos en función de la categoría del Sistema.

A modo general, en todo control de acceso se requerirá lo siguiente:

- a) Que todo acceso esté prohibido, salvo concesión expresa.
- b) Que la entidad (usuario) quede identificada singularmente [op.acc.1].
- c) Que la utilización de los recursos esté protegida [op.acc.2].
- d) Que se definan para cada entidad los siguientes parámetros: a qué se necesita acceder, con qué derechos y bajo qué autorización [op.acc.4].
- e) Serán diferentes las personas que autorizan, usan y controlan el uso [op.acc.3].
- f) Que la identidad de la entidad quede suficientemente autenticada [op.acc.5].
- g) Que se controle tanto el acceso local ([op.acc.6]) como el acceso remoto ([op.acc.7]).

3 Firma electrónica

La firma, a diferencia de la autenticación, no persigue solamente demostrar que una persona es quien dice ser, sino que, respecto del acto en el que plasma dicha firma, muestra una voluntad expresa de consentimiento o voluntad.

En el mundo analógico estamos muy familiarizados con la firma ológrafa:

La firma o rúbrica, también conocida como firma manuscrita y como firma ológrafa, es una escritura gráfica o grafo manuscrito que representa el nombre y apellido, o título, que una persona escribe de su propia mano, y tiene fines identificativos, jurídicos, representativos y diplomáticos.

Por supuesto, **previa a la firma, debe verificarse que quien firma es la persona que dice ser** (identificación y autenticación).

En el mundo analógico, normalmente si el acto es relevante, se firma ante un tercero que ejerce de testigo. Si el acto tiene repercusiones de gran impacto es posible que debe realizarse ante un notario que de fe formal de dicho consentimiento (por ejemplo, la firma de una hipoteca o el aval para un crédito) o ante una autoridad competente (firma de un convenio, de un matrimonio, etc.).

En el mundo digital, **la firma electrónica de documentos digitales** supone un escenario distinto pues existen una serie de retos respecto a la operativa de un documento firmado en papel.

3.1 Definición de firma electrónica

El Reglamento eIDAS, que veremos en detalle en el próximo capítulo, contempla tres tipos de firma:

Firma simple, que en el eIDAS se referencia como firma electrónica sin más adjetivos, firma avanzada y firma cualificada.

- La **firma simple** (firma electrónica a secas) se define como “los datos en formato electrónico anejos a otros datos electrónicos o asociados de manera lógica con ellos que utiliza el firmante para firmar. “
- La **firma avanzada, definida en el artículo 26 del eIDAS**, consiste en un conjunto de datos electrónicos que acompañan o que están asociados a un documento electrónico y que además cumple cuatro requisitos contemplados en dicho artículo: Estar vinculado al firmante de forma única; permitir identificar al firmante; haber sido creada utilizando datos de creación de la firma electrónica que el firmante puede utilizar, con un alto nivel de confianza, bajo su control exclusivo, y estar vinculada con los datos firmados por la misma de modo tal que cualquier modificación ulterior de los mismos sea detectable.
- **Firma cualificada**, una firma electrónica avanzada que se crea mediante un dispositivo cualificado de creación de firmas electrónicas y que se basa en un certificado cualificado de firma electrónica.

Parece deseable que la firma cumpla una serie de objetivos, que sí se cumplen a partir de la firma avanzada, a saber:

- **Identificar al firmante de manera inequívoca.**
- **Asegurar la integridad del documento firmado.** Asegura que el documento firmado es exactamente el mismo que el original y que no ha sufrido alteración o manipulación.
- **Asegurar el no repudio posterior.** Los datos que utiliza el firmante para realizar la firma son únicos y exclusivos y, por tanto, posteriormente, no podrá negar que haya firmado el documento.

Esto que parece sencillo tiene implementaciones diferentes, que, según su rigurosidad, reciben diferentes calificaciones y reconocimientos legales posteriores (ver capítulo 4).

Ejemplos de aplicación de la firma electrónica de hoy en día:

- Usando una firma biométrica (por ejemplo, la huella dactilar). (Sería firma cualificada si se usa conjuntamente con un dispositivo cualificado y un algoritmo de un certificado cualificado)
- Firma con un lápiz electrónico al usar una tarjeta de crédito o débito en una tienda (Ídem que el caso anterior).
- Marcando una casilla en una aplicación implementada adecuadamente a este fin (sería una firma simple).
- Con el ratón o con el dedo en una pantalla táctil en una aplicación de firma (Ídem que el primer ejemplo).
- Usando una firma digital proporcionada por una aplicación que la implemente. (Dependiendo de la aplicación podría ser cualquiera de los tres tipos).
- Usando usuario y contraseña, como por ejemplo Cl@ve (con registro previo). (sería firma avanzada)
- Usando una tarjeta de coordenadas proporcionada por el banco. (Sería firma avanzada siempre y cuando el banco utilice algoritmos adecuados tanto para la generación de dichas tarjetas como para la elaboración y custodia de la firma generada en la transacción en la que se use).

Consideraciones a tener en cuenta:

- Si se quiere que la firma electrónica tenga una validez legal reforzada, tanto por la legislación nacional como europea deberá ser al menos **firma electrónica avanzada**, lo que implica que la firma esté sustentada en certificados electrónicos que reúnan una serie de características tales como la garantía de su autenticidad y su integridad, que veremos en breve.
- No obstante, las firmas simples (no avanzadas), también pueden tener validez jurídica (artículo 25.1 reglamento eIDAS).
- La firma electrónica no dota de confidencialidad al documento que se firma.
- Digitalizar una firma (con un escáner, por ejemplo) no la convierte automáticamente en una firma electrónica avanzada. Si se quiere utilizar un documento firmado en papel en un procedimiento electrónico deberá estarse a lo que se dispone en la legislación al respecto, en particular a la Norma Técnica de Interoperabilidad de Digitalización de documentos.

El concepto de Firma Electrónica implica por tanto una serie de condiciones, usos, garantías sobre lo firmado y sobre la identidad del firmante todo ello regulado a nivel nacional por una ley, la Ley 59/2003 y a nivel europeo por el Reglamento eIDAS. En el siguiente capítulo se detallará la normativa de aplicación.

3.2 Firma de los interesados en los procedimientos administrativos

El artículo 10 de la Ley 39/2015 establece los medios que pueden utilizar los interesados para firmar en los procedimientos administrativos comunes:

“1. Los interesados podrán firmar a través de cualquier medio que permita acreditar la autenticidad de la expresión de su voluntad y consentimiento, así como la integridad e inalterabilidad del documento.

2. En el caso de que los interesados optarán por relacionarse con las Administraciones Públicas a través de medios electrónicos, se considerarán válidos a efectos de firma:

a) Sistemas de firma electrónica reconocida o cualificada y avanzada basados en certificados electrónicos reconocidos o cualificados de firma electrónica expedidos por prestadores incluidos en la «Lista de confianza de prestadores de servicios de certificación».

A estos efectos, se entienden comprendidos entre los citados certificados electrónicos reconocidos o cualificados los de persona jurídica y de entidad sin personalidad jurídica.

b) Sistemas de sello electrónico reconocido o cualificado y de sello electrónico avanzado basados en certificados electrónicos reconocidos o cualificados de sello electrónico incluidos en la «Lista de confianza de prestadores de servicios de certificación».

c) Cualquier otro sistema que las Administraciones Públicas consideren válido, en los términos y condiciones que se establezcan.

Cada Administración Pública, Organismo o Entidad podrá determinar si sólo admite algunos de estos sistemas para realizar determinados trámites o procedimientos de su ámbito de competencia.

3. Cuando así lo disponga expresamente la normativa reguladora aplicable, las Administraciones Públicas podrán admitir los sistemas de identificación contemplados en esta Ley como sistema de firma cuando permitan acreditar la autenticidad de la expresión de la voluntad y consentimiento de los interesados.

4. Cuando los interesados utilicen un sistema de firma de los previstos en este artículo, su identidad se entenderá ya acreditada mediante el propio acto de la firma.

3.2.1 Obligatoriedad de la firma en procesos administrativos

La Ley 39/2015 establece en su Capítulo II, en particular en el artículo 11.2 el ámbito en el que la Administración requerirá la firma dentro de un Proceso Administrativo Común.

2. Las Administraciones Públicas sólo requerirán a los interesados el uso obligatorio de firma para:

a) Formular solicitudes.

b) Presentar declaraciones responsables o comunicaciones.

c) Interponer recursos.

d) Desistir de acciones.

e) Renunciar a derechos.

Así pues, en estos cinco supuestos se exigirá la firma del interesado en el procedimiento en cuestión.

3.3 Firma de múltiples usuarios Co-firma y Contrafirma

A veces un procedimiento electrónico implica el consentimiento de varios implicados en dicho procedimiento.

En el mundo del papel y de la firma manuscrita, un documento puede contener la firma de varias personas:

En un caso, las firmas pueden tener el mismo peso o valor legal, por lo que da igual el orden en el que se estampan las firmas en el documento.

Otro caso, es el que unas firmas sirven para refrendar o certificar otras firmas anteriores, por lo que el orden en el que se estampan las firmas es importante.

El equivalente a esas firmas en el mundo electrónico son las firmas múltiples. Atendiendo al criterio del número de firmantes podemos tener:

Firmas simples. Son las firmas básicas que contienen la firma de un solo firmante.

- **Co-firma o firma en línea.** Es la firma múltiple en la que todos los firmantes están al mismo nivel y en la que no importa el orden en el que se firma. La co-firma se utiliza en la firma de documentos que son resultados de reuniones, conferencias o comités.
- **Contra-firma o firma en cascada.** Firma múltiple en la que el orden en el que se firma es importante, ya que cada firma debe refrendar o certificar la firma del firmante anterior. La contra-firma se utiliza especialmente en aplicaciones como los Porta Firmas, en los que un documento debe seguir una línea específica a través de varios firmantes hasta que todo el proceso es aprobado.

Las aplicaciones de firma @Firma y eCoFirma permiten ambas los tres tipos de firma. En ellas, el usuario puede elegir el tipo de firma múltiple que desea realizar. La aplicación FirmaFácil automáticamente selecciona la co-firma cuando se le presenta para firmar un documento firmado previamente.

3.4 Firma y Sello de las Administraciones Públicas

El artículo 42 de la Ley 40/2015 establece los medios de firma y sello para la actuación administrativa automatizada:

Artículo 42 Sistemas de firma para la actuación administrativa automatizada

En el ejercicio de la competencia en la actuación administrativa automatizada, cada Administración Pública podrá determinar los supuestos de utilización de los siguientes sistemas de firma electrónica:

- a) Sello electrónico de Administración Pública, órgano, organismo público o entidad de derecho público, basado en certificado electrónico reconocido o cualificado que reúna los requisitos exigidos por la legislación de firma electrónica.*
- b) Código seguro de verificación vinculado a la Administración Pública, órgano, organismo público o entidad de Derecho Público, en los términos y condiciones establecidos, permitiéndose en todo caso la comprobación de la integridad del documento mediante el acceso a la sede electrónica correspondiente.*

En el apartado a) debemos remitirnos a la definición de sello electrónico en el contexto que veremos en el siguiente capítulo relativo al reglamento eIDAS.

A continuación, veremos el concepto de Código Seguro de Verificación.

3.5 Código Seguro de Verificación (CSV)

Vinculado a la Administración pública, órgano o entidad y, en su caso, a la persona firmante del documento, permitiéndose en todo caso la comprobación de la autenticidad e integridad del documento electrónico impreso mediante el acceso a la sede electrónica correspondiente.

Aunque puede haber ciertas diferencias, a veces es también llamado Código de Verificación Electrónica (CVE) o localizador. Las copias realizadas en soporte papel de documentos públicos administrativos emitidos por medios electrónicos y firmados electrónicamente tendrán la consideración de copias auténticas siempre que incluyan la impresión de un código generado electrónicamente u otros sistemas de verificación que permitan contrastar su autenticidad mediante el acceso a los archivos electrónicos de la Administración Pública, órgano o entidad emisora

El documento electrónico se referencia con dos componentes, por un lado, la identificación de la sede electrónica y por otro el localizador del documento en la sede, de forma que se verifica la autenticidad e integridad de la copia auténtica.

3.6 Sellado de Tiempo

El sellado de tiempo es un método para probar que un conjunto de datos existió antes de un momento dado y que ninguno de estos datos ha sido modificado desde entonces.

El **Sello de Tiempo** es una firma de una **Autoridad de Sellado de Tiempo** (TSA), que actúa como tercera parte de confianza testificando la existencia de dichos datos electrónicos en una fecha y hora concretos.

El sellado de tiempo proporciona un valor añadido a la utilización de firma digital, ya que la firma por sí sola no proporciona ninguna información acerca del momento de creación de la firma, y en el caso de que el firmante la incluyese, ésta habría sido proporcionada por una de las partes, cuando lo recomendable es que la marca de tiempo sea proporcionada por una tercera parte de confianza.

Es importante aclarar que existe lo que se denomina “**marca de tiempo**”, que la proporciona el sistema donde se realiza la firma y, por tanto, no es válido a efectos de constatar de forma fehaciente la fecha y hora oficial en la que se realizó la firma.

3.6.1 Resellado

Puesto que el Sello de Tiempo es una firma realizada con el certificado electrónico de la Autoridad de Sellado, cuando ese certificado caduque, el sello y, por tanto, la firma dejan de ser válidos.

Por eso, antes de que el certificado de la TSA caduque es necesario resellar o aplicar de nuevo el Sello Temporal para mantener la validez temporal de la firma.

4 Legislación europea y nacional de firma electrónica

En el ámbito nacional contamos con una Ley de Firma que está afectada por un Reglamento Europeo posterior y para el sector público, de un ENI y una Política de firma para la AGE.

4.1 Reglamento Europeo de Identificación y legislación afín UE

En el ámbito europeo, el **Reglamento Europeo de Identificación electrónica y servicios de confianza 910/2014** del Parlamento Europeo y del Consejo, de 23 de julio de 2014 **deroga la antigua Directiva (Directiva 1999/93/CE)**. **Este Reglamento se conoce como eIDAS y es de aplicación efectiva desde el 1 de julio del 2016, en la parte referente a los servicios de confianza.**

Como todos los reglamentos de la UE, es de directa trasposición. Dado que colisiona con la Ley 59/2003 de Firma Electrónica, ésta ha sido revisada parcialmente y deberá seguir en proceso de adaptación al eIDAS, pero no queda derogada, sino que, en lo que haya controversia, se atenderá a lo que dice el Reglamento europeo al respecto.

Este Reglamento establece las condiciones en que los Estados miembros deberán reconocer los **medios de identificación electrónica de las personas físicas y jurídicas** pertenecientes a un sistema de identificación electrónica notificado de otro Estado miembro, así como las normas para los **servicios de confianza** y un marco jurídico para las **firmas electrónicas, los sellos electrónicos, los sellos de tiempo electrónicos, los documentos electrónicos, los servicios de entrega electrónica certificada y los servicios de certificados para la autenticación de sitios web.**

El Reglamento tiene como objetivo la creación de un clima de confianza online para el desarrollo económico y social, garantizando la seguridad jurídica de consumidores, empresas y Administraciones públicas en sus transacciones electrónicas y animándoles a adoptar los nuevos servicios, lo que traerá como consecuencia un incremento de la eficacia de los servicios públicos y privados, los negocios electrónicos y el comercio electrónico en la Unión Europea.

Posteriormente a este reglamento se han sucedido varias Decisiones UE que detallan conceptos tales como la **Decisión de Ejecución (UE) 2015/1506** de la Comisión de 8 de septiembre por la que se establecen las especificaciones relativas a los formatos de las firmas electrónicas avanzadas y los sellos avanzados que deben reconocer los organismos del sector público de conformidad con el Reglamento eIDAS.

También es preciso mencionar el **Reglamento de Ejecución (UE) 2015/1502** de la Comisión de 8 de septiembre por el que se establecen las especificaciones y procedimientos técnicos mínimos para los niveles de seguridad de los medios de identificación electrónica.

Como vemos, este reglamento y la legislación afín afecta tanto a la firma electrónica como también a todos sus elementos relacionados tales como los sellos de tiempo, los documentos electrónicos y a la forma de prestar los servicios por parte de la Administración para que sean servicios de confianza.

El Reglamento aborda dos grandes ámbitos:

- El reconocimiento mutuo transfronterizo de identidades electrónicas (eID).
- La utilización de los servicios de confianza (Trust Services o TS) regulando los servicios de creación, verificación y validación de: Firma electrónica, sellos electrónicos, sellos de tiempo electrónicos, servicios de entrega electrónica certificada y servicios de certificados para la autenticación de sitios web.

4.1.1 Novedades del Reglamento

El Reglamento eIDAS introduce una serie de novedades que es preciso comentar con más detalle:

- **El Reconocimiento mutuo de identidades electrónicas.**

Anteriormente, no estaba garantizado que los ciudadanos de un estado miembro pudieran identificarse electrónicamente en otro estado miembro utilizando los medios habituales de identificación electrónica de su país de origen.

El Reglamento eIDAS garantiza el reconocimiento y aceptación mutua de los sistemas de identificación notificados por cada Estado miembro en el resto de Estados.

Ahora bien, los Estados miembros no están obligados a notificar sistema alguno. Del mismo modo, la posibilidad de autenticarse en un servicio público online de otro Estado miembro no implica que se posea el derecho a acceder a ese servicio o a recibir prestación alguna, sino que se refiere simplemente a que ha de existir la posibilidad de autenticación online en servicios públicos online prestados por Administraciones de otros países de la UE utilizando medios de identificación previamente notificados a la Comisión Europea.

Por su parte, la Comisión Europea elaborará y publicará una lista con los medios de eID notificados y que son objeto de reconocimiento mutuo.

Es importante destacar que la validación de una identidad electrónica en el acceso a un servicio público online ha de ser gratuita para el ciudadano y no debe implicar tampoco cargas para el servicio accedido.

La obligación de reconocimiento del sistema de identificación electrónica en el acceso a los servicios públicos habrá de aplicarse únicamente cuando el organismo del sector público en cuestión emplee el nivel de seguridad “sustancial” o “alto” en el acceso a dicho servicio en línea. En cuanto a los sistemas de eID con nivel de seguridad “bajo”, los Estados podrán notificarlos, pero no serán objeto de reconocimiento mutuo.

- **Desaparición de los certificados de persona jurídica**

Un primer cambio es la **desaparición de los certificados de persona jurídica y de entidades sin personalidad jurídica**, lo que ha afectado a los que actualmente se manejaban en España de estos tipos. Estos certificados se podrán usar hasta su caducidad y, a partir de entonces, sólo se podrán usar certificados de persona física, si bien se han contemplado los siguientes certificados: Certificados de representante de persona jurídica, de representante de entidad sin personalidad jurídica y de representante para administradores únicos y solidarios.

4.1.2 Breve resumen del contenido del reglamento

El Reglamento eIDAS consta de 6 capítulos, de los que nos centraremos por su contenido relevante a este tema en los tres primeros.

El primer capítulo denominado “Disposiciones Generales” contiene como relevante el artículo 3 en el que se exhiben las definiciones que se usarán a lo largo del resto del articulado. En relación con lo que hemos visto en el capítulo 2 relativo a la autenticación, se definen en este reglamento tres conceptos esenciales:

- **Identificación electrónica(eID):** Proceso de utilizar los datos de identificación de una persona en formato electrónico que representan de manera única a una persona física o jurídica o a una persona física que representa a una persona jurídica.
- **Medios de identificación electrónica:** Una unidad material y/o inmaterial que contiene los datos de identificación de una persona y que se utiliza para la autenticación en servicios en línea.
- **Sistema de identificación electrónica:** Un régimen para la identificación electrónica en virtud del cual se expiden medios de identificación electrónica a las personas físicas o jurídicas o a una persona física que representa a una persona jurídica.

Respecto a lo que hemos visto en el capítulo anterior relativo a la firma electrónica, se introducen en este reglamento los siguientes conceptos esenciales:

- Firmante: Una persona física que crea una firma electrónica.
- Firma electrónica: Los datos en formato electrónico anejos a otros datos electrónicos o asociados de manera lógica con ellos que utiliza el firmante para firmar.
- Firma electrónica avanzada: La firma electrónica que cumple los requisitos contemplados en el artículo 26 (capítulo III, sección 4):
 - a) Estar vinculada al firmante de manera única.
 - b) Permitir la identificación del firmante.
 - c) Haber sido creada utilizando datos de creación de la firma electrónica que el firmante puede utilizar, con un alto nivel de confianza, bajo su control exclusivo.
 - d) Estar vinculada con los datos firmados por la misma de modo tal que cualquier modificación ulterior de los mismos sea detectable.
- Firma electrónica cualificada: Una firma electrónica avanzada que se crea mediante un dispositivo cualificado de creación de firmas electrónicas y que se basa en un certificado cualificado de firma electrónica.
- Datos de creación de la firma electrónica: Los datos únicos que utiliza el firmante para crear una firma electrónica.
- Certificado de firma electrónica: Una declaración electrónica que vincula los datos de validación de una firma con una persona física y confirma, al menos, el nombre o el seudónimo de esa persona.
- Certificado cualificado de firma electrónica: Un certificado de firma electrónica que ha sido expedido por un prestador cualificado de servicios de confianza y que cumple los requisitos establecidos en el anexo I:
 - a) Una indicación, al menos en un formato adecuado para el procesamiento automático, de que el certificado ha sido expedido como certificado cualificado de firma electrónica.
 - b) Un conjunto de datos que represente inequívocamente al prestador cualificado de servicios de confianza que expide los certificados cualificados, incluyendo como mínimo el Estado miembro en el que dicho prestador está establecido. Para personas jurídicas: el nombre y, cuando proceda, el número de registro según consten en los registros oficiales. Para personas físicas, el nombre de la persona.
 - c) Al menos el nombre del firmante o un seudónimo; si se usara un seudónimo, se indicará claramente.
 - d) Datos de validación de la firma electrónica que correspondan a los datos de creación de la firma electrónica.
 - e) Los datos relativos al inicio y final del período de validez del certificado.
 - f) El código de identidad del certificado, que debe ser único para el prestador cualificado de servicios de confianza.
 - g) La firma electrónica avanzada o el sello electrónico avanzado del prestador de servicios de confianza expedidor.
 - h) El lugar en que está disponible gratuitamente el certificado que respalda la firma electrónica avanzada o el sello electrónico avanzado a que se hace referencia en la letra g).
 - i) La localización de los servicios que pueden utilizarse para consultar el estado de validez del certificado cualificado.
 - j) Cuando los datos de creación de firma electrónica relacionados con los datos de validación de firma electrónica se encuentren en un dispositivo cualificado de creación de firma electrónica, una indicación adecuada de esto, al menos en una forma apta para el procesamiento automático.

- Dispositivo cualificado de creación de firmas electrónicas: Un dispositivo de creación de firmas electrónicas que cumple los requisitos enumerados en el anexo II:
 - 1. Los dispositivos cualificados de creación de firma electrónica garantizarán como mínimo, por medios técnicos y de procedimiento adecuados, que:
 - a) Esté garantizada razonablemente la confidencialidad de los datos de creación de firma electrónica utilizados para la creación de firmas electrónicas.
 - b) Los datos de creación de firma electrónica utilizados para la creación de firma electrónica solo puedan aparecer una vez en la práctica.
 - c) Exista la seguridad razonable de que los datos de creación de firma electrónica utilizados para la creación de firma electrónica no pueden ser hallados por deducción y de que la firma está protegida con seguridad contra la falsificación mediante la tecnología disponible en el momento.
 - d) Los datos de creación de la firma electrónica utilizados para la creación de firma electrónica puedan ser protegidos por el firmante legítimo de forma fiable frente a su utilización por otros.
 - 2. Los dispositivos cualificados de creación de firmas electrónicas no alterarán los datos que deben firmarse ni impedirán que dichos datos se muestren al firmante antes de firmar.
 - 3. La generación o la gestión de los datos de creación de la firma electrónica en nombre del firmante solo podrán correr a cargo de un prestador cualificado de servicios de confianza.
 - 4. Sin perjuicio de la letra d) del punto 1, los prestadores cualificados de servicios de confianza que gestionen los datos de creación de firma electrónica en nombre del firmante podrán duplicar los datos de creación de firma únicamente con objeto de efectuar una copia de seguridad de los citados datos siempre que se cumplan los siguientes requisitos:
 - a) La seguridad de los conjuntos de datos duplicados es del mismo nivel que para los conjuntos de datos originales;
 - b) El número de conjuntos de datos duplicados no supera el mínimo necesario para garantizar la continuidad del servicio.

Como podemos apreciar en estas definiciones, se ha intentado aunar la seguridad de la firma electrónica con la versatilidad que pueden proporcionar los servicios en la nube de firma.

En el segundo capítulo denominado “**Identidad Electrónica**” se establece los niveles de seguridad de los sistemas de identificación electrónica presentados en el capítulo anterior, que se detallan en el siguiente apartado.

En el tercer capítulo se detalla lo que se entiende por **Servicios de Confianza** (ver apartado 4.1.4)

4.1.3 Niveles de seguridad de los sistemas de autenticación

El Reglamento define tres niveles de seguridad (Bajo, Sustancial y Alto) de los sistemas de identificación y autenticación y las consecuencias derivadas de esta categorización:

- **Básico**: Se debe reducir el riesgo de uso indebido o de alteración de la identidad.
- **Sustancial**: Se debe reducir sustancialmente el riesgo de uso indebido o de alteración de la identidad.
- **Alto**: Se debe evitar el riesgo de uso indebido o de alteración de la identidad.

Estos niveles de seguridad reflejan el grado de confianza de un medio de identificación electrónica para establecer la identidad de una persona, garantizando así que la persona que afirma poseer una identidad determinada es de hecho la persona a quien se ha atribuido dicha identidad, teniendo en cuenta los procedimientos técnicos, (por ejemplo, prueba y verificación de la identidad, autenticación),

las actividades de gestión (como la entidad que expide los medios de identificación electrónica, el procedimiento para expedir dichos medios) y los controles aplicados.

El Reglamento de Ejecución UE 2015/1502 de la Comisión Europea de 8 de septiembre define las especificaciones y procedimientos técnicos mínimos para los niveles de seguridad.

En este Reglamento se han tenido en cuenta tanto la Norma ISO 29115 como los resultados de los proyectos STORK.

En primer lugar, el Reglamento introduce una serie de definiciones básicas:

- Fuente auténtica: Cualquier fuente, independientemente de la forma, en la que se pueda confiar para proporcionar datos, información o pruebas exactos que se puedan utilizar para demostrar la identidad (como vimos en el capítulo 2, se está refiriendo al proceso de Identificación).
- Factor de Autenticación: Un factor confirmado como vinculado a una persona, que se encuentra en alguna de las categorías siguientes:
 - **Factor de autenticación basado en la posesión**: Factor de autenticación en el que el sujeto está obligado a demostrar posesión del mismo.
 - **Factor de autenticación basado en el conocimiento**: Factor de autenticación en el que el sujeto está obligado a demostrar conocimiento del mismo.
 - **Factor de autenticación inherente**: Factor de autenticación que se basa en un atributo físico de una persona física del cual el sujeto está obligado a demostrar su posesión.

(Como se puede apreciar, estas definiciones también se asemejan a lo que vimos en el capítulo 2 sobre factores de autenticación estándares, correspondiéndose el basado en el conocimiento con el que se definió como simple, como puede ser una contraseña, el factor basado en la posesión, como, por ejemplo, una tarjeta de coordenadas o un tóken, y el inherente ligado a lo que es la persona o hace, como puede ser el iris, la voz, el reconocimiento facial, etc.)
- Autenticación Dinámica: Proceso electrónico que utiliza criptografía u otras técnicas para proporcionar un medio de crear a petición una prueba electrónica que demuestre que el sujeto controla o posee los datos de identificación y que cambia con cada autenticación entre el sujeto y el sistema que verifica la identidad del sujeto.
- Sistema de gestión de la Seguridad de la Información: Conjunto de procesos y procedimientos diseñados para gestionar a niveles aceptables los riesgos relacionados con la seguridad de la información.

Respecto a las especificaciones y procedimientos, por resumir, es preciso comentar que respecto a los procedimientos se consideran los siguientes:

- Procedimiento de inscripción.
- Procedimiento de gestión de medios de identificación electrónica.
- Procedimiento de autenticación y procedimiento de gestión y organización.

Todos estos procedimientos diferencian los requisitos por niveles de seguridad (básico, sustancial y alto).

4.1.4 Nuevos Servicios de Confianza

Un servicio de confianza, tal y como define eIDAS, es un **servicio electrónico prestado habitualmente a cambio de una remuneración, de alguno de estos tipos**:

- La **creación, verificación y validación de firmas electrónicas, sellos electrónicos o sellos de tiempo electrónicos, servicios de entrega electrónica certificada** y certificados relativos a estos servicios.
- La **creación, verificación y validación de certificados para la autenticación de sitios web**.
- La **preservación de firmas, sellos o certificados electrónicos** relativos a estos servicios.

Es importante destacar que no existe la obligación general de utilizar estos servicios ni de instalar un punto de acceso para todos los servicios de confianza existentes. Es decir, el Reglamento no exige a todos los organismos públicos la obtención del equipo y los programas informáticos necesarios para la legibilidad técnica de todos los servicios de confianza existentes.

Por otro lado, el Reglamento no cubre la prestación de servicios utilizados exclusivamente dentro de sistemas cerrados entre un conjunto definido de participantes, que no tengan efectos en terceros. Por ejemplo, los sistemas establecidos en Administraciones públicas para gestionar procedimientos internos que hagan uso de servicios de confianza no están sujetos a las obligaciones del Reglamento.

Pero sí están regulados los servicios de confianza prestados al público que tengan efectos en terceros.

Los servicios de confianza cualificados son los que están definidos en el Reglamento.

- **Firma Electrónica:**
 - El artículo 25 determina los efectos jurídicos de la firma electrónica:
 - No se niegan efectos jurídicos a las firmas electrónicas que no sean cualificadas si bien se consideran válidas de pleno derecho sólo las firmas cualificadas, que además deberán ser reconocidas en todos los Estados miembros.
 - El artículo 27 establece que los organismos públicos de los estados miembros deberán, además, admitir las firmas electrónicas avanzadas que cumplan con determinados requisitos que se han precisado posteriormente en la Decisión de Ejecución UE 2015/1506.
 - Los artículos 28 y 29 están referidos a los certificados cualificados de firma electrónica y a los dispositivos cualificados de firma electrónica (que ya vimos en las definiciones).
 - El artículo 30 establece la obligatoriedad de la evaluación de seguridad para los dispositivos cualificados de creación de firmas.
- **Validación de firmas electrónicas:** Este servicio se regula en los artículos 32 y 33:
 - Para verificar una firma electrónica cualificada se debe comprobar que:
 - El certificado asociado a la firma fuera en ese momento un certificado cualificado de firma, válido según el prestador del certificado en el momento de la firma.
 - Los datos de validación de la firma se corresponden con los datos proporcionados para su verificación y con los datos que representan al firmante en el certificado de firma.
 - La firma ha utilizado un dispositivo cualificado de creación de firmas.
 - No se ha comprometido la integridad de los datos firmados.
 - Se hayan cumplido, además, todos los requisitos de firma electrónica avanzada.

- **Sello Electrónico:**

- El sello electrónico está basado en un certificado de sello, y no debe confundirse con un certificado de persona jurídica. El paradigma instaurado en el Reglamento es claro al respecto: las personas físicas firman y las personas jurídicas sellan.
- La clasificación de los sellos electrónicos es similar a la de las firmas. **Un sello electrónico avanzado** cumplirá los requisitos siguientes:
 - a) estar vinculado al creador del sello de manera única;
 - b) permitir la identificación del creador del sello;
 - c) haber sido creado utilizando datos de creación del sello electrónico que el creador del sello puede utilizar para la creación de un sello electrónico, con un alto nivel de confianza, bajo su control.
 - d) estar vinculado con los datos a que se refiere de modo tal que cualquier modificación ulterior de los mismos sea detectable.
- **Sello electrónico cualificado:** Presunción de integridad de los datos y de la corrección del origen de los datos a los que el sello electrónico cualificado esté vinculado, con autenticidad del origen e integridad del contenido.
 - Un sello electrónico cualificado basado en un certificado cualificado emitido en un Estado miembro será reconocido como un sello electrónico cualificado en todos los demás Estados miembros.
- Se incorporan además dos servicios para los sellos: Servicio cualificado de verificación de sellos electrónicos cualificados y Servicio cualificado de conservación de sellos electrónicos cualificados.

- **Sellado de Tiempo:** Para garantizar en el futuro la validez de lo firmado.

- **Un sello cualificado de tiempo electrónico cumple los siguientes requisitos:**
 - Vincula la fecha y hora con los datos de forma que se elimina razonablemente la posibilidad de modificar los datos sin que se detecte.
 - Se basa en una fuente de información temporal vinculada al Tiempo Universal Coordinado (UTC).
 - Ha sido firmado mediante el uso de una firma electrónica avanzada o sellada con un sello electrónico avanzado del prestador cualificado de servicios de confianza o por cualquier método equivalente.

- **Entrega electrónica certificada:**

- El artículo 43 establece una analogía jurídica entre los efectos jurídicos para la firma con los de la entrega electrónica certificada. Presupone que los datos enviados de este modo no han sido alterados siempre que cumplan los requisitos establecidos en el artículo 44.
- El artículo 44 establece los requisitos de entrega certificada:
 - a) Ser prestados por uno o más prestadores cualificados de servicios de confianza.
 - b) Asegurar con un alto nivel de fiabilidad la identificación del remitente.
 - c) Garantizar la identificación del destinatario antes de la entrega de los datos.
 - d) Estar protegidos el envío y recepción de datos por una firma electrónica avanzada o un sello electrónico avanzado de un prestador cualificado de servicios de confianza de tal forma que se impida la posibilidad de que se modifiquen los datos sin que se detecte.

- e) Indicar claramente al emisor y al destinatario de los datos cualquier modificación de los datos necesarios a efectos del envío o recepción de los datos.
 - f) Indicar mediante un sello cualificado de tiempo electrónico la fecha y hora de envío, recepción y eventual modificación de los datos.
- En caso de que los datos se transfieran entre dos o más prestadores cualificados de servicios de confianza, se aplicarán los requisitos establecidos en las letras a) a f) a todos los prestadores cualificados de servicios de confianza.
- **Servicio cualificado de autenticación de sitio web:**
 - El artículo 45 remite al Anexo IV para los requisitos de los servicios cualificados de autenticación para sitio web, que deberán incluir:
 - a) Una indicación, al menos en un formato adecuado para el procesamiento automático, de que el certificado ha sido expedido como certificado cualificado de autenticación de sitio web.
 - b) Un conjunto de datos que represente inequívocamente al prestador cualificado de servicios de confianza que expide los certificados cualificados, incluyendo como mínimo el Estado miembro en el que dicho prestador está establecido. Para personas jurídicas: el nombre y, cuando proceda, el número de registro según consten en los registros oficiales. Para personas físicas, el nombre de la persona
 - c) El nombre de la persona para la que se expide el certificado o un seudónimo que, caso de usarse, se indicará claramente. Para personas jurídicas al menos el nombre de la persona jurídica para la que se expida el certificado y cuando proceda, el registro según figure en los registros oficiales.
 - d) Elementos de la dirección, incluida al menos la ciudad y el Estado, de la persona física o jurídica a quien se expida el certificado, y, cuando proceda, según figure en los registros oficiales.
 - e) El nombre o los nombres de dominio explotados por la persona física o jurídica a la que se expida el certificado.
 - f) Los datos relativos al inicio y final del período de validez del certificado.
 - g) El código de identidad del certificado, que debe ser único para el prestador cualificado de servicios de confianza.
 - h) La firma electrónica avanzada o el sello electrónico avanzado del prestador de servicios de confianza expedidor.
 - i) El lugar en que está disponible gratuitamente el certificado que respalda la firma electrónica avanzada o el sello electrónico avanzado a que se hace referencia en la letra h).
 - j) La localización de los servicios que pueden utilizarse para consultar el estado de validez del certificado cualificado.

Los servicios de confianza regulados podrán ser utilizados como prueba en procedimientos judiciales en todos los Estados miembros, aunque corresponde al Derecho nacional definir sus efectos jurídicos, salvo disposición contraria del Reglamento. Del mismo modo, las legislaciones nacionales podrán introducir disposiciones adicionales, siempre que no se haya realizado una armonización completa en el Reglamento, así como definir otros tipos de servicios de confianza a nivel nacional más allá de los que figuran en la lista cerrada de servicios regulados por él.

El reglamento es tecnológicamente neutro y abierto a innovaciones, pudiéndose lograr por cualquier medio técnico los efectos jurídicos que otorga siempre que se cumplan los requisitos que en él se estipulan.

Por último, otra importante excepción es que **el Reglamento no aplica a los requisitos nacionales de formato correspondientes a los registros públicos**, en particular los registros mercantiles y de la propiedad.

4.2 Legislación Nacional

4.2.1 Ley de Firma

La Ley de Firma (Ley 59/2003 introduce las garantías legales que se han de aplicar para que la firma digital se convierta en firma electrónica y, además, pueda ser utilizada con plenas garantías jurídicas en los procedimientos administrativos.

A continuación, repasaremos los conceptos fundamentales que dicha ley introduce:

En el artículo 3 de la Ley 59/2003 (Ley de Firma Electrónica) se nos define:

- **Firma electrónica:**

Firma electrónica es el conjunto de datos en forma electrónica, consignados junto a otros o asociados con ellos, que pueden ser utilizados como medio de identificación del firmante.

- **Firma electrónica avanzada:**

Es la firma electrónica que permite identificar al firmante y detectar cualquier cambio ulterior de los datos firmados, que está vinculada al firmante de manera única y a los datos a que se refiere y que ha sido creada por medios que el firmante “**puede mantener bajo su exclusivo control**” (redacción original) y con motivo de la Ley 25/2015 de 28 de julio de mecanismo de segunda oportunidad, reducción de la carga financiera y otras medidas de orden social se cambió por “**puede utilizar, con un alto nivel de confianza, bajo su exclusivo control**”.

- **Firma electrónica reconocida:**

Es la firma electrónica **avanzada** basada en un **certificado reconocido** y generada mediante un **dispositivo seguro** de creación de firma.

La firma electrónica reconocida tendrá respecto de los datos consignados en forma electrónica el mismo valor que la firma manuscrita en relación con los consignados en papel.

En los siguientes artículos se da detalles sobre la validez de la firma:

9. No se negarán efectos jurídicos a una firma electrónica que no reúna los requisitos de firma electrónica reconocida en relación a los datos a los que esté asociada por el mero hecho de presentarse en forma electrónica.

10. A los efectos de lo dispuesto en este artículo, cuando una firma electrónica se utilice conforme a las condiciones acordadas por las partes para relacionarse entre sí, se tendrá en cuenta lo estipulado entre ellas.

11. Todos los sistemas de identificación y firma electrónica previstos en la Ley de Procedimiento Administrativo Común de las Administraciones Públicas y en la Ley de Régimen Jurídico del Sector Público tendrán plenos efectos jurídicos.

Además, **se da validez legal también a la firma electrónica avanzada** puesto que se dice en el artículo 8 que: “Si se impugna la autenticidad de la firma electrónica avanzada, con la que se hayan

firmado los datos incorporados al documento electrónico, se estará a lo establecido en el apartado 2 del artículo 326 de la Ley de Enjuiciamiento Civil" que además remite a las definiciones del artículo 3 para la verificación probatoria de la firma.

Con objeto de evitar la obsolescencia tecnológica, los certificados también poseen un periodo máximo de validez. **La Ley 59/2003, de firma electrónica, ha sido modificada por la Ley 9/2014, General de Telecomunicaciones, de forma que el plazo máximo de validez de los certificados reconocidos para firma electrónica es de 5 años.**

4.2.2 Esquema Nacional de Interoperabilidad

El Real Decreto 4/2010 de 8 de enero que establece el Esquema Nacional de Interoperabilidad (en adelante ENI), en su Capítulo IX define las condiciones de interoperabilidad que deben cumplir tanto la firma electrónica como los certificados electrónicos empleados.

El **artículo 18** del ENI indica que la AGE tiene que definir una política de firma que servirá de marco general de interoperabilidad para la autenticación y el reconocimiento mutuo de firmas electrónicas dentro de su ámbito de actuación (AGE) pero que puede usarse de modelo por parte del resto de la Administración. Esta política de firma ya está establecida (ver epígrafe siguiente).

Dicho artículo también establece que los certificados de firma generados dentro del marco de esta política deberán ser interoperables y mutuamente reconocidos entre diferentes administraciones públicas.

El **artículo 19** regula los aspectos de interoperabilidad que deben cumplir los prestadores de servicios de certificación.

El **artículo 20** se refiere a las plataformas de validación de certificados y firma electrónica.

4.2.3 Norma Técnica de Interoperabilidad de Política de firma y sello electrónicos y de certificados de la Administración

Como novedad apuntar que el 27 de octubre del 2016 se aprobó la **Norma Técnica de Interoperabilidad de Política de Firma y Sello Electrónicos y de Certificados de la Administración**.

Sustituye a la anterior Norma Técnica de Interoperabilidad del 2012 denominada de Política de Firma Electrónica y de certificados de la Administración.

Esta nueva versión se persigue la alineación con la Decisión de Ejecución UE/2015/1506 de la Comisión que contiene las especificaciones relativas a los formatos de las firmas electrónicas avanzadas y los sellos avanzados que deben reconocer los organismos del sector público.

Esta NTI establece el conjunto de criterios para el desarrollo o adopción de políticas de firma y sello electrónicos basada en certificados por parte de las Administraciones públicas. Para ello, define el contenido de una política de firma electrónica y sello electrónico basados en certificados, especificando las características de las reglas comunes, como formatos, uso de algoritmos, creación y validación de firma para documentos electrónicos, así como de las reglas de confianza en certificados electrónicos, sellos de tiempo y firmas longevas.

4.2.4 La Política de Firma Electrónica de la AGE

Una política de firma electrónica aborda las normas relativas a los aspectos más relevantes en relación a la firma electrónica: Generación y validación de firma en el contexto de la organización donde se aplique, definiendo las reglas y obligaciones de todos los actores involucrados en dicho proceso.

El objetivo de este proceso es determinar la validez de la firma electrónica para una actuación en particular, especificando la información que deberá proporcionar el firmante en el proceso de generación de la firma, y la información que deberá comprobar el verificador en el proceso de validación de la misma.

La Política de Firma de la AGE versión 1.9 se aprobó por la Comisión Permanente del Consejo Superior de Administración Electrónica el 30/05/2012 y se publicó en el Boletín Oficial del Estado núm. 299 de 13 de diciembre. Está tangencialmente afectada por la NT de Interoperabilidad anteriormente mencionada.

- Incluye las normas relativas a la firma electrónica, organizadas alrededor de los conceptos de generación y validación de firma.
- Incluye los perfiles interoperables de los medios de identificación de las AAPP de la Ley 40/2015: los certificados de sede, sello electrónico y empleado público.
- Asociada a un contexto dado, que es la firma de Documentos Electrónicos Administrativos.
- Permite reforzar la confianza en las transacciones electrónicas.
- Define las reglas y obligaciones de todos los actores involucrados en un proceso de firma.
- Permite determinar la validez de la firma electrónica para una transacción en particular.

4.2.5 Futura Ley de Servicios de Confianza

Como consecuencia del Reglamento europeo eIDAS, está en anteproyecto la futura Ley de Servicios de Confianza.

Esta Ley regulará los aspectos que el Reglamento europeo deja al albur de los Estados miembros, tales como el régimen de previsión de riesgo de los prestadores cualificados, el régimen sancionador, la comprobación de la identidad y atributos de los solicitantes de un certificado cualificado, la inclusión de requisitos adicionales a nivel nacional para certificados cualificados tales como identificadores nacionales o su tiempo máximo de vigencia, así como las condiciones para la suspensión de los certificados.

4.2.6 Esquema Nacional de Seguridad

Por último, mencionar que el ENS hace referencia a las condiciones de seguridad de la firma electrónica:

Artículo 33. Firma electrónica.

1. Los mecanismos de firma electrónica se aplicarán en los términos indicados en el Anexo II de esta norma y de acuerdo con lo preceptuado en la política de firma electrónica y de certificados, según se establece en el Esquema Nacional de Interoperabilidad.

2. La política de firma electrónica y de certificados concretará los procesos de generación, validación y conservación de firmas electrónicas, así como las características y requisitos exigibles a los sistemas de firma electrónica, los certificados, los servicios de sellado de tiempo, y otros elementos de soporte de las firmas, sin perjuicio de lo previsto en el Anexo II, que deberá adaptarse a cada circunstancia.

En el anexo II, en el control “mp.info.4” (firma electrónica) es relevante que, **a partir de sistemas categorizados de nivel medio, se especifica que se emplearán algoritmos y parámetros acreditados por el Centro Criptológico Nacional.**

Para nivel alto además se indica que se usará firma electrónica cualificada, incorporando certificados cualificados y dispositivos cualificados de creación de firma y se emplearán productos certificados conforme a lo establecido en el control “op.pl.5”.

El control “mp.info.5” hace referencia al uso de sellos de tiempo que, para nivel alto, deberán usarse sellos cualificados, y productos certificados según el control “op.pl.5”.

5 Certificados digitales

Un certificado digital o certificado electrónico es un fichero generado por una de servicios de certificación y que sirve para autenticar a una persona o a un sitio web en Internet.

El certificado digital tiene como función principal autenticar al poseedor del certificado, pero puede servir también para cifrar las comunicaciones y firmar digitalmente.

El concepto de PKI (Public Key Infrastructure) con el detalle de qué son las CA (autoridades de certificación, autoridades de registro, algoritmos usados de clave pública, etc.) se detallará en el siguiente tema.

Con el Reglamento eIDAS, las tipologías de certificados existentes de la Ley 59/2003 (persona física, persona jurídica, entidad sin personalidad jurídica,) y los establecidos por la Ley 11/2007 (sello electrónico y sede electrónica), son sustituidas por las nuevas recogidas en este reglamento:

- **Autenticación web.**
- **Firma.**
- **Sello.**

5.1 Certificados de Servidor X.509v3 para autenticación web

Estos certificados se utilizan para demostrar la autenticidad de los sitios web y para establecer conexiones seguras vía SSL/TLS con los clientes que acceden y que se autentican en el sitio web correspondiente.

La autenticidad del sitio web en cuestión se garantiza mediante el uso de un certificado de servidor web que debe estar, a su vez, avalado por una Autoridad de Certificación (CA) que es la que da fe de que dicho certificado es correcto. A veces unas CA se avalan en cascada, conformando una cadena de confianza en los certificados. La CA raíz o primordial debe estar reconocida y preinstalada con el sistema operativo porque, de lo contrario, fallaría la cadena de confianza y el navegador nos mostraría un mensaje de error.

Los navegadores de internet usan mecanismos para detectar si algunos certificados presentan anomalías o disconformidades que puedan suponer un problema de seguridad para los usuarios.

Cuando el navegador cree que un certificado es correcto (desde sus pautas de comprobación) suele indicarlo con un símbolo tal como un candadito verde o símbolo análogo, cuando no es así por algún motivo, lo marca y explica sucintamente dicho motivo, lo cual no siempre indica que el sitio web no sea seguro, a veces puede ocurrir que no tenga información suficiente para comprobar todas las condiciones de seguridad del certificado en cuestión, pero ya supone una alerta para el usuario que debe sopesar si acceder o no.

Los navegadores web no darán por válido un certificado si:

- No ha sido emitido por una autoridad de certificación reconocida por el navegador. Cada autoridad de certificación está incluida en una serie de navegadores por defecto, conviene revisar la lista de compatibilidad de cada autoridad de certificación para saber cuál es la que se adapta a las necesidades concretas de cada caso.
- Si el nombre que aparece en el certificado no coincide con el del sitio web al que se está accediendo. Por ejemplo, si el certificado ha sido emitido para el nombre de web "ventavinomuybueno.dominio.com" no puede ser utilizado para que los usuarios accedan de forma segura a "ventavinomuymalo.dominio.com".
- Que no esté caducado, revocado o que no esté todavía en vigor. Al emitir el certificado la autoridad de certificación (CA) marca: La fecha a partir de la cual comienza a ser válido el certificado y la fecha a partir de la cual deja de ser válido el certificado. En el momento de la

conexión la hora actual tiene que estar entre ambas fechas, es decir, en el periodo de vida útil del certificado.

En algunos navegadores como Chrome está un poco complicado ver la información completa del certificado, pero se puede obtener a través del menú Herramientas para Desarrolladores en la pestaña Security.

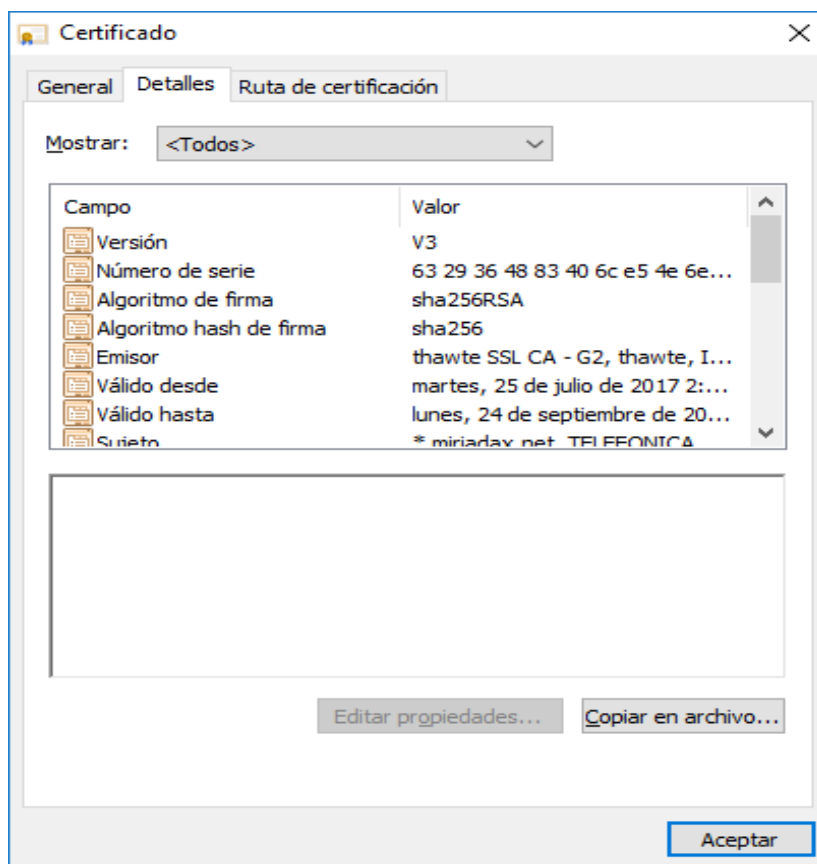


Figura 2 Ejemplo de certificado de servidor válido. Pestaña Detalles con la información de los campos correspondientes. Está tomada del sitio miriadax.net

Cuando se habla comúnmente de certificados X.509v3, se trata de certificados especificados mediante el RFC 3280 (IETF PKIX), que flexibilizó el estándar ITU-T para adaptarlo a Internet (ver capítulo 8, la relación entre X.500 y X.509). Su sintaxis se define empleando el lenguaje ASN.1.

Los campos más importantes que incluye un certificado X.509v3 son:

- **Version:** versión del certificado (en este caso ya hemos dicho que son v3).
- **Serial Number:** identificador del certificado, ha de ser único para cada CA. En la figura de arriba de ejemplo vemos que comienza por 63 29 36 (está escrito en código hexadecimal).
- **Signature Algorithm:** identifica el algoritmo usado por la CA para firmar el certificado (típicamente, RSA o DSA). Vemos en la figura de arriba que es RSA y sha256 para firma.
- **Issuer:** nombre de la CA que expide el certificado, en este caso **thawte**.
- **Validity period:** tiempo de validez (Valid From, Valid To). En el ejemplo desde el 25 de julio del 2017 hasta el 24 de septiembre del 2018.
- **Subject:** contiene los datos que identifican al sujeto titular asociado con la clave pública contenida en el certificado, expresados en notación DN (Distinguished Name), que se

compone de diversos campos, como CN (Common Name), OU (Organizational Unit), O (Organization) y C (Country). Téngase en cuenta que el sujeto puede ser una persona, un servidor o un servicio. Ver lo referente a relación entre X.500 y X.509.

- **Subject public key information:** clave pública del titular, indicando el algoritmo utilizado para crearla (lo que la legislación denomina “datos de validación de firma”).
- **Extensions:** introducidas en X.509v3. Permiten una gran flexibilidad. Constan de tres partes: “Extension ID”, “Critical” (si una extensión está categorizada como crítica, su ausencia implicará el rechazo del certificado), “Value”. Destacan:
 - Subject alternative name. Contiene identidades adicionales ligadas al titular del certificado, e.g. la dirección de email del sujeto, o un LDAP distinguished name, o una URL, o una dirección IP, o un nombre DNS.
 - Key Usage. Define el uso que se puede dar al certificado. Es fuente de problemas de interoperabilidad por sus diferentes interpretaciones. Se definieron:
 - digitalSignature: para autenticación.
 - nonRepudiation / contentCommitment: para firma digital.
 - keyEncipherment.
 - dataEncipherment.
 - keyAgreement.
 - keyCertSign: para certificados de CA.
 - cRLSign: para firma de CRL.
 - encipherOnly.
 - decipherOnly.
 - Basic Constraints: Indica si el certificado se utiliza como emisor de certificados finales, es decir, si es un certificado de CA.
 - Extended Key Usage. Indica uno o más fines para los cuales se puede utilizar la clave pública, además de los fines básicos indicados en el campo “KeyUsage”. Incluye un Object Identifier (OID) globalmente único de cada aplicación para la que se puede usar el certificado. E.g., los certificados que firman las Listas de Servicios de Confianza (TSL) poseen el OID 0.4.0.2231.3.0 específico del citado uso.
 - CRL distribution points (CDP) y Freshest CRL (Delta CRL Distribution Point). Uno o más enlaces a la ubicación de las CRL y la Delta CRL.
 - Certificate policies. Describe las políticas de identificación del titular previas a la expedición del certificado que ha seguido la CA.
 - Authority Information Access (AIA), uno o más enlaces a la ubicación del servidor OCSP de la Autoridad de Validación (VA).
 - Issuer digital signature: la CA añade la firma digital de los campos y extensiones previos, indicando el algoritmo de firma utilizado y el hash de la firma. Así vincula al issuer con su clave pública.

Los identificadores únicos de emisor y titular fueron introducidos en la versión 2, que tuvo una existencia efímera. No obstante, estas mejoras opcionales sirvieron para identificar al titular o emisor en caso de reasignaciones de Distinguished Name (DN).

Se debe tener en cuenta que la estructura de la CA es jerárquica, por lo que el certificado raíz, del que nacen todos los demás, es un certificado autofirmado.

5.1.1 Solicitudes de Certificados

Un CSR (Certificate Signing Request) es la petición de certificado que se envía a la autoridad de certificación. Mediante la información contenida en el CSR la autoridad de certificación puede emitir el certificado una vez realizadas las comprobaciones que correspondan.

Para realizar dicha solicitud, el solicitante, utilizando ciertas funciones del software del servidor web, completa ciertos datos de identificación y genera una pareja de claves que serán las claves pública y privada del certificado.

Con esa información, se genera un fichero que contiene una petición CSR (Certificate Signing Request) en formato **PKCS#10**, conteniendo la clave pública generada, y que se envía a la CA elegida para realizar la petición.

Esta CA, tras verificar por sí o mediante los servicios de una Autoridad de Registro (RA-Registration Authority) la información de identificación aportada y la realización del pago por el servicio, envía el certificado firmado al solicitante, que lo instala en el servidor web con la misma herramienta con la que generó la petición CSR.

En este contexto, PKCS corresponde a un conjunto de especificaciones que son estándares de facto denominadas Public-Key Cryptography Standards.

5.2 Certificados de firma

Estos certificados se utilizan para validar y certificar que una firma electrónica se corresponde con una persona o entidad concreta.

Es, análogamente a los certificados de sitio web, un documento electrónico emitido por una Autoridad de Certificación, pero en vez de validar un sitio web, se trata de validar la identidad del firmante.

La Ley 59/2003, de firma electrónica, establece que “un certificado electrónico es un documento firmado electrónicamente por un prestador de servicios de certificación que vincula unos datos de verificación de firma a un firmante y confirma su identidad”. O, como lo expresa el Reglamento (UE) 910/2014, certificado de firma electrónica es “una declaración electrónica que vincula los datos de validación de una firma con una persona física y confirma, al menos, el nombre o el seudónimo de esa persona”.

Como veremos más en profundidad en el capítulo 6, el certificado digital utiliza la criptografía asimétrica para dar respuesta a la necesidad de conocer fehacientemente que una determinada clave pública corresponde a la identidad de un usuario o entidad concreta durante un determinado periodo de tiempo, evitando suplantaciones de identidades.

La Ley 39/2015 es coherente con el Reglamento eIDAS y admite, por tanto, como certificados de firma a usar en el procedimiento administrativo común (artículo 10.a) los siguientes:

- Sistemas de firma electrónica reconocida o cualificada y avanzada basados en certificados electrónicos reconocidos o cualificados de firma electrónica expedidos por prestadores incluidos en la «Lista de confianza de prestadores de servicios de certificación».
- A estos efectos, se entienden comprendidos entre los citados certificados electrónicos reconocidos o cualificados los de persona jurídica y de entidad sin personalidad jurídica.

Los certificados de persona jurídica y de entidad sin personalidad jurídica emitidos antes del 1 de julio de 2016 podrán seguir utilizándose hasta su caducidad o revocación, pero no podrán renovarse después de esa fecha. Los certificados emitidos como reconocidos se relacionarán en la base de datos nacional y en la lista de confianza de prestadores de servicios de certificación como certificados no reconocidos (Decisión de ejecución (UE) 2015/1505).

Para solucionar el problema relativo a los certificados de persona jurídica (dejaron de emitirse el 1 de julio del 2016), se han previsto **certificados de persona física representante**:

- Certificado de Representante para Administrador Único o Solidario.
- Certificado de Representante de Persona Jurídica.
- Certificado de Representante de Entidad sin Personalidad Jurídica.

5.2.1 Estándar X509 para certificados de firma

Al igual que para los certificados de sitio web, se usa el estándar X509 propuesto por la ITU también para los certificados de firma. Cambian algunos de los algoritmos a usar y las extensiones correspondientes, teniéndose para el caso de la firma las extensiones PKCS para algoritmos de criptografía asimétrica, como por ejemplo PKCS#7 usado para firmar el correo electrónico con S/MIME o la PKCS#12 para almacenar la clave privada de firma. Otros algoritmos como los de PKCS#10 para solicitar un certificado a la Autoridad de Certificación son similares a los que se usan para solicitar un certificado de sitios web.

5.3 Certificados de sello

Un certificado de Sello Electrónico vincula unos datos de verificación de firma a los datos identificativos y de autenticación de determinada Administración, organismo o entidad y la persona física representante de la Administración, organismo o entidad Titular del certificado y, en su caso, el personal en quien se delegue a efectos de la actuación administrativa automatizada.

Los certificados de sello, como hemos visto, se usan por tanto para la actuación administrativa automatizada. La Ley 39/2015 prevé su uso por parte de los interesados en los procedimientos administrativos (9.2.b):

“Sistemas basados en certificados electrónicos reconocidos o cualificados de sello electrónico expedidos por prestadores incluidos en la «Lista de confianza de prestadores de servicios de certificación.»

También el artículo 10.2 de dicha Ley 39/2015 establece que se considerarán válidos, a efectos de firma, entre otros, los sellos electrónicos cualificados:

“... Sistemas de sello electrónico reconocido o cualificado y de sello electrónico avanzado basados en certificados electrónicos reconocidos o cualificados de sello electrónico incluidos en la «Lista de confianza de prestadores de servicios de certificación.»

5.3.1 Certificados cualificados de sello

Los requisitos de sello electrónico cualificado se encuentran en el anexo III del Reglamento. Las condiciones son equivalentes a los certificados de firma electrónica, tanto en la posibilidad de introducir campos adicionales a nivel nacional, como en las opciones de suspensión temporal y revocación.

La diferencia sustancial es que ahora en vez de “firmante” se habla de “creador del sello”, y deberá constar su nombre y número de registro oficial.

5.4 Comprobación del estado de los certificados

Para comprar el estado de los certificados, las CA mantienen la lista de los certificados emitidos que están en vigor, los caducados y los revocados (aquellos que antes de la fecha de expiración han dejado de ser confiables por algún motivo).

La revocación del certificado la puede pedir el propietario del mismo, pero también un tercero con interés legítimo si advierte que se está haciendo abuso del mismo, término que tiene que ser dirimido por la CA.

La lista de los certificados revocados se denomina CRL (Certificate Revocation List), esta consulta es pública, pero dado que puede ser de gran tamaño, en vez de descargarla entera, lo más habitual es consultarla de forma online vía protocolos OCSP o SCVP. Los mensajes OCSP se codifican en ASN.1 y habitualmente se transmiten sobre el protocolo HTTP. SCVP valida además la cadena del certificado con las CAs correspondientes, pero es más complejo de utilizar.

Debido al gran número de entidades certificadoras existentes, y a pesar de las medidas de seguridad que emplean para la correcta verificación de personas físicas y jurídicas, existe el riesgo de que una CA emita un certificado a un defraudador con una identidad falsa.

Como no existe un registro de qué certificados han sido emitidos por cada CA, no es fácil detectar qué casos se han filtrado de manera fraudulenta o qué certificados refieren a un nombre igual o muy parecido al de otra entidad. Para evitar este tipo de problemas, Google ha lanzado la iniciativa **certificate transparency**, que registra todos los certificados emitidos por las CA a través de unos ficheros de auditoría criptográficamente infalsificables.

6 Claves públicas, privadas y concertadas

Para realizar la firma electrónica, es preciso manejar varias claves. El firmante deberá contar con su clave privada de firma, que sólo él podrá usarla y que generará, como hemos visto anteriormente, la firma electrónica correspondiente.

La clave pública de firma deberá ser conocida por el remitente para poder comprobar posteriormente la identidad del remitente a partir de la firma enviada.

La seguridad de la firma electrónica avanzada y el hecho de que sea confiable y aceptada legalmente radica en la robustez del uso de criptografía asimétrica basada en algoritmos avalados.

No obstante, el eslabón más débil en esta cadena es el usuario, ya que debe custodiar y manipular correctamente su clave privada.

La firma electrónica reconocida añade la seguridad del dispositivo de creación de la firma, garantizando que dicho dispositivo está siempre bajo la custodia del firmante.

El próximo tema ampliará la información sobre la forma en la que se guardan estas claves, así como los mecanismos para la creación de firma más habituales tales como las tarjetas conocidas como SmartCards, entre las que se encuentra el DNI electrónico. También es posible usar claves contenidas en tokens, llaves usb, etc., en vez de tarjetas físicas (por ejemplo, los certificados que emite la FNMT).

El Reglamento (UE) 910/2014 abre la posibilidad de realizar firmas remotas o firmas en la nube, en las que el certificado digital no se encuentra en posesión física del titular, sino alojado en un dispositivo conocido como Hardware Security Module (HSM), así como firma móvil. En línea con esto, como vimos, se modificó la Ley de Firma Electrónica la definición de firma electrónica avanzada.

El firmante puede confiar a un tercero el dispositivo de creación de firma, a condición de que se apliquen los procedimientos y mecanismos adecuados para garantizar que el firmante tiene el control exclusivo del uso de la clave privada.

A fin de garantizar que estas firmas obtengan el mismo reconocimiento jurídico que las firmas electrónicas creadas en un entorno completamente gestionado por el usuario, los prestadores que ofrezcan servicios de firma electrónica a distancia deben aplicar procedimientos de seguridad de la gestión y administrativos específicos y utilizar sistemas y productos fiables, incluidos canales de comunicación electrónica seguros para garantizar que el entorno de creación de firmas electrónicas es fiable y se utiliza bajo el control exclusivo del firmante.

En el próximo tema se extenderá el concepto de HSM, así como el DNI 3.0 y otros mecanismos que utilizan esta misma reinterpretación de lo que se considera tener bajo el control exclusivo del firmante del dispositivo seguro de creación de la firma.

Asimismo, el próximo tema se extenderá en los formatos del fichero de almacenamiento de las claves privadas de firma, la familia PKCS#12

6.1 Procedimiento criptográfico de firma electrónica

Aunque este procedimiento es prácticamente transparente para el firmante gracias a las aplicaciones y dispositivos de firma, vamos a detallar un poco dicho procedimiento:

1. Sobre el documento electrónico a firmar, se genera un hash, resumen o huella digital (ver el tema relativo a las funciones resumen). Llamaremos **m (M)** a este resumen.
2. Este resumen o huella digital se cifra con la clave privada que tiene el firmante y que se puede aplicar al documento en cuestión. Es importante notar que el firmante debe seleccionar la clave de firma adecuada al documento que se firma, pues puede que disponga de varias firmas con varios roles distintos y sólo uno aplique al documento que está firmando. Llamaremos **f (m (M))** a este resumen firmado.
3. Este resumen cifrado se adjunta con el mensaje original y se envía al destinatario.

4. El destinatario aplicará la misma función resumen al mensaje, $m(M)$
5. A continuación, descifrará usando la clave pública de firma del remitente este resumen, llamaremos g a la operación de descifrado: $g([f(m(M))])$.

Debe coincidir el resultado del paso 6 con $m(M)$.

6.2 Claves concertadas

Puesto que la Ley 39/2015 permite identificarse y firmar en ciertos casos usando claves concertadas, a continuación, se recoge el ejemplo más importante de su uso hasta ahora: Cl@ve.

Hablaremos antes de un proyecto precursor llamado PIN24h.

6.2.1 PIN24h

PIN24h fue un proyecto de autenticación con registro de claves temporal, realizado por la Agencia Tributaria, fue una alternativa al típico REN0 donde se pide siempre el conocimiento de una determinada casilla de la declaración del año anterior.

Se ha continuado en Cl@ve con la opción de clave ocasional.

Se basaba en un sistema de One Time Password (OTP), que tenía una validez temporal y que se usaba básicamente para realizar gestiones sencillas y rápidas tales como la gestión del borrador de la declaración de la renta anual.

El procedimiento de uso era el siguiente:

- El contribuyente debía registrarse previamente en la sede electrónica, bien con un código CSV de la carta invitación remitida por la AEAT o bien con certificado electrónico reconocido (por ejemplo, el típico de la FNMT). También podía hacerlo presencialmente en las oficinas de la Agencia Tributaria con el DNI.
- A continuación, la composición del PIN constaba de dos partes: por un lado, la clave personal que elige el contribuyente cada vez que solicita un PIN24H (Clave de Acceso) y, por otro lado, el PIN24H que envía posteriormente la Agencia Tributaria al móvil del usuario por SMS cuando lo solicita (PIN24H). **Código de acceso= Clave de Acceso + PIN24H**

6.2.2 Cl@ve

El ejemplo más actual de la sistematización del uso de claves concertadas por parte de la Administración que ha supuesto un caso de éxito por su exportación a múltiples procedimientos es Cl@ve.

Su objetivo principal es que el ciudadano pueda identificarse ante la Administración mediante claves concertadas (usuario más contraseña), sin tener que recordar claves diferentes para acceder a los distintos servicios.

Mediante el registro previo del ciudadano en este servicio, puede autenticarse en todos los procedimientos administrativos que admitan este sistema que, en la actualidad, es muy numeroso.

Para poder utilizar estas claves concertadas y los servicios de firma en la nube, los ciudadanos deberán registrarse previamente en el sistema, aportando los datos de carácter personal necesarios.

Cl@ve complementa los actuales sistemas de acceso mediante DNI-e y certificado electrónico, y ofrece la posibilidad de realizar firma en la nube con certificados personales custodiados en servidores remotos.

Se trata de una plataforma común para la identificación, autenticación y firma electrónica, un sistema interoperable y horizontal que evita a las Administraciones Públicas tener que implementar y gestionar sus propios sistemas de identificación y firma, y a los ciudadanos tener que utilizar métodos de identificación diferentes para relacionarse electrónicamente con la Administración.

En función de la categoría del sistema (ENS) al que va a acceder el usuario, se define en qué modo se debe utilizar.

El ciudadano usuario de los servicios de administración electrónica puede entonces escoger el identificador que desea usar entre los disponibles para el nivel de aseguramiento requerido por la aplicación a la que va a acceder

Opciones de uso:

- **Cl@ve ocasional** (Cl@ve PIN): sistema de contraseña tipo OTP (One Time Password) de validez muy limitada en el tiempo, orientado a usuarios que acceden esporádicamente a los servicios, que se corresponde con el sistema PIN24H de la AEAT. El PIN enviado por SMS sólo puede ser utilizado una vez para acceder al sistema. Además, hay que utilizar el PIN recibido antes de los 10 minutos, ya que, pasado ese tiempo sin haber accedido a Cl@ve hay que solicitar un nuevo PIN. Una vez identificado mediante el PIN se puede acceder a los servicios que permitan Cl@ve hasta que la desconexión del usuario de la Sede Electrónica o el cierre del navegador utilizado.
- **Cl@ve permanente**: sistema de contraseña de validez duradera en el tiempo, pero no ilimitada, orientado a usuarios habituales. Se corresponde con el sistema de acceso mediante usuario y contraseña, reforzado con claves de un solo uso por SMS, a los servicios de Seguridad Social. Este sistema será además el que permitirá el acceso al ciudadano a la firma en la nube.

Elementos del sistema:

El diseño de Cl@ve está basado en un sistema de federación de identidades electrónicas, que integra diferentes elementos:

- **Proveedores de servicios de administración electrónica (SP)**: Entidades que proporcionan servicios electrónicos a los ciudadanos y utilizan la plataforma para la identificación y autenticación de los mismos.
- **Proveedores de servicios de identificación y autenticación (IdP)**: Entidades que proporcionan mecanismos de identificación y autenticación de los ciudadanos para ser utilizados como medios comunes por otras entidades.
- **Pasarela / Gestor de Identificación**: Sistema intermediador que posibilita el acceso de los proveedores de servicios a los distintos mecanismos de identificación y la selección de éstos por parte del usuario.

De acuerdo con este diseño, los proveedores de servicios únicamente tienen que integrarse con el Gestor de Identificación, encargándose éste de establecer las relaciones pertinentes con los distintos sistemas de identificación. Para ello se establecen relaciones de confianza entre los distintos actores que se integran entre sí, soportadas por el intercambio de certificados electrónicos y el envío de mensajes firmados entre ellos, que garantizan la transmisión segura de la información durante todo el proceso de identificación y autenticación.

Este proyecto ha partido de la Gerencia de Informática de la Seguridad Social (GISS).

Adicionalmente, Cl@ve está preparada para incorporar en el futuro, conforme se vayan integrando en el sistema de reconocimiento transfronterizo de identidades electrónicas previsto en la legislación europea, mecanismos de identificación de otros países de la Unión Europea.

7 Formatos de firma electrónica

El formato de firma es la forma como se genera el documento de firma y como se guarda o estructura la información de firma en el documento generado.

La existencia de múltiples formatos de firma se debe a razones históricas, a cómo se ha ido introduciendo la firma en formatos de documentos ya existentes y a cómo se han ido añadiendo funcionalidades a lo largo del tiempo.

El formato del fichero de firma depende de los siguientes aspectos:

- Estructura del fichero: formatos CAdES, XAdES, PAdES, OXML, ODF...
- Dónde se guarda el documento original.
- Firmas con múltiples usuarios.
- Longevidad de la firma y sello de tiempo.

Cómo se estructura esta información (el orden de esa información dentro del fichero, las etiquetas que indican cuándo empieza un campo y cuándo termina, la opcionalidad de esos campos, etc.) viene determinado por los distintos formatos.

7.1 Formatos de firma más comunes

Algunas aplicaciones de firma dejan elegir el formato a utilizar (@Firma). Otras imponen siempre el mismo formato (eCoFirma) y otras deciden automáticamente el formato en función del formato original del documento a firmar (@FirmaFácil).

7.1.1 CAdES (CMS Avanzado)

Es la evolución del primer formato de firma estandarizado. Es apropiado para firmar ficheros grandes, especialmente si la firma contiene el documento original porque optimiza el espacio de la información. Tras firmar, no podrás ver la información firmada, porque la información se guarda de forma binaria.

7.1.2 XAdES (XML Avanzado)

El resultado es un fichero de texto XML, un formato de texto muy similar al HTML que utiliza etiquetas. Los documentos obtenidos suelen ser más grandes que en el caso de CAdES, por eso no es adecuado cuando el fichero original es muy grande. Aplicaciones como eCoFirma del Ministerio de Industria y Comercio, sólo firman en XAdES.

7.1.3 PAdES (PDF Avanzado)

Este es el formato más adecuado cuando el documento original es un pdf. El destinatario de la firma puede comprobar fácilmente la firma y el documento firmado. Con los formatos anteriores esto no es posible si no se utilizan herramientas externas.

7.1.4 OOXML y ODF

Son los formatos de firma que utilizan Microsoft Office y Open Office, respectivamente.

7.2 Firmas Longevas y formatos

Para verificar una firma es necesario realizar una serie de comprobaciones:

- **Comprobar la integridad de los datos firmados**, para verificar que no hayan sufrido ninguna modificación.
- **Comprobar que el certificado con el que se firmó era el correcto**, es decir, que estaba vigente en el momento en que se realizó la operación de firma.

Esto plantea una serie de interrogantes:

- ¿Cómo sabemos que un certificado estaba vigente en un instante perteneciente al pasado? Las herramientas estándar sólo nos dicen si un certificado está vigente hoy.
- En el futuro, ¿qué deberá hacerse para validar una firma hecha hoy, aunque el certificado haya caducado entonces?

Para dar respuesta a estas preguntas, los formatos **AdES (forma genérica de llamar a los formatos CAdES, XAdES y PAdES)** contemplan la posibilidad de incorporar a las firmas electrónicas información adicional que garantiza la **validez de una firma a largo plazo**, una vez vencido el periodo de validez del certificado.

Estos formatos añaden a la firma evidencias de terceros (de autoridades de certificación) y certificaciones de tiempo que realmente certifican cuál era el estado del certificado en el momento de la firma.

Firma Básica (AdES - BES), es el formato básico para satisfacer los requisitos de la firma electrónica avanzada. A esta firma básica se le añadirán características adicionales:

- **AdES - T**, se añade un sellado de tiempo (T de TimeStamp) con el fin de situar en el tiempo el instante en que se firma un documento.
- **AdES - C**, añade un conjunto de referencias a los certificados de la cadena de certificación y su estado, como base para una verificación longeva (C de Cadena).
- **AdES - X**, añade sellos de tiempo a las referencias creadas en el paso anterior (X de eXtendida).
- **AdES - XL**, añade los certificados y la información de revocación de los mismos, para su validación a largo plazo (XL de eXtendido Largo plazo).
- **AdES - A**, permite la adición de sellos de tiempo periódicos para garantizar la integridad de la firma archivada o guardada para futuras verificaciones (A de Archivo).

Además de los formatos de firma, se incorporan al proceso de firma una serie de servicios que aplican a la firma electrónica de documentos para ofrecer garantías deseables tales como dar fe de cuándo se firmó, la comprobación de documentos firmados cuando se imprimen en papel o la verificación del certificado de las sedes electrónicas.

La verificación de las claves de firma de los firmantes se verá en el tema siguiente donde se hablará de @Firma.

7.3 Firmas attached, detached, enveloped, enveloping

Atendiendo en cómo se organiza el contenedor de la firma y el documento firmado se habla de:

- **Firma detached:** Cuando la firma está en un documento separado del que se firma.
- **Firma attached:** Cuando la firma y el documento que se firma van juntos.

En el caso de CAdES y PAdES, la firma está embebida en el documento que se firma, pero en el caso de XAdES, documento y firma pueden ir por separado (detached).

En el caso de **firma attached**, a su vez podemos tener:

- **Firma enveloping:** Si el fichero de firma es el que contiene al documento que se firma.
- **Firma enveloped:** Si la firma está incrustada en el documento que se firma.

7.4 Formatos admitidos por las AAPP y Reglamento e IDAS

Los formatos de firma admitidos por las AAPP en el procedimiento electrónico están regulados por la Norma Técnica de Interoperabilidad de Política de Firma y Sellos Electrónicos y de Certificados de la Administración (ver la referencia en el apartado 4.2.3).

Esta NTI está alineada con la Decisión de Ejecución UE/2015/1506 de la Comisión que contiene las especificaciones relativas a los formatos de las firmas electrónicas avanzadas y los sellos avanzados que deben reconocer los organismos del sector público.

En particular y en lo concerniente a los formatos de firma electrónica, **la NTI establece lo siguiente:**

“III.2 Formatos admitidos de firma electrónica.

1. Los formatos admitidos por las organizaciones para las firmas/sellos electrónicos basadas en certificados electrónicos, se ajustarán a:

a) la «Decisión de Ejecución UE 2015/1506» o en la que la sustituya, de conformidad con los artículos 27, apartado 5, y 37, apartado 5, del «Reglamento (UE) no 910/2014 del Parlamento Europeo y del Consejo, relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior».

b) lo establecido en la NTI de Catálogo de estándares.

c) los formatos CAdES, XAdES y PAdES en las versiones establecidas en la Norma Técnica de Interoperabilidad de Política de firma del 2011.

2. Los formatos de firma/sello electrónico serán

a) Si procede, interoperables con la política marco en la que se basan.”

El apartado a) que hace mención a la citada Decisión UE 2015/1506 nos remite al artículo I de dicha decisión que se concreta en el Anexo que aquí resumimos:

Se admiten los formatos de firma avanzadas en XML, CMS o PDF deben cumplir respectivamente con las especificaciones ETSI:

- Perfil de base XAdES debe cumplir la especificación ETSI TS 103171 v2.1.1
- Perfil de base CAdES debe cumplir la especificación ETSI TS 103173 v.2.2.1
- Perfil de base PAdES debe cumplir la especificación ETSI TS 103172 v.2.2.2

Además, el contenedor de la firma debe cumplir con la especificación ETSI TS 103174 v.2.2.1

En cuanto a los sellos electrónicos la NTI establece:

“III.4 Formatos de firma/sello electrónico de contenido.

1. Los formatos para la firma/sello electrónico de contenido se ajustarán a la «Decisión de Ejecución UE 2015/1506» o en la que la sustituya, de conformidad con los artículos 27, apartado 5, y 37, apartado 5, del «Reglamento (UE) 910/2014»

2. Por compatibilidad con las políticas de firma anteriores, se permitirán aunque no se recomiendan los siguientes formatos:

a) XAdES (XML Advanced Electronic Signatures), según la especificación técnica ETSI TS 101 903, versión 1.2.2 y versión 1.3.2.

b) CAdES (CMS Advanced Electronic Signatures), según la especificación técnica ETSI TS 101 733, versión 1.6.3 y versión 1.7.4.

c) PAdES (PDF Advanced Electronic Signatures), según la especificación técnica ETSI TS 102 778-3.”

La Decisión UE mencionada establece en el Anexo las mismas especificaciones que las enumeradas para la firma y su contenedor.

La NTI indica, además, que el formato que se utilizará para la generación de firmas de contenido será –EPES, es decir, BES añadiendo la información relativa a la política de firma y sello.

La NTI también da información sobre los formatos de firma válidos para los documentos electrónicos, así como las reglas para la creación de las firmas electrónicas. Menciona el formato de firma para facturas electrónica que debe ser **Facturae**.

Por último, respecto al uso de algoritmos para la creación de las claves de firma, la NTI indica que se deben seguir los estándares indicados por el Centro Criptológico Nacional, en particular, la guía CCN-STIC-807 sobre Criptografía de empleo.

8 Protocolos de directorio basados en LDAP y X.500

Cuando se accede a una red o a un sistema de una organización, normalmente la gestión de accesos a dicho sistema se encuentra automatizada mediante el uso por dicha entidad de un recurso llamado directorio.

Un Directorio es un conjunto de objetos con atributos diversos que se organiza de forma jerárquica.

En el mundo analógico tenemos por ejemplo una guía telefónica o un fichero de clientes.

Como se indica, el interés del uso de este tipo de estructuras es porque automatiza la identificación, la autenticación y la autorización, ya que los usuarios que se dan de alta en dichos sistemas serán entradas de dicho directorio y los atributos serán, entre otros, el identificador de acceso, el hash de la contraseña (no se suele incorporar la contraseña tal cual por seguridad), y los recursos del sistema a los que se le ha dado acceso.

El Directorio se suele implementar habitualmente con el sistema operativo del sistema, tal como es el caso del Directorio Activo de Windows. En este caso, el Directorio se conserva en una base de datos que suele estar distribuida y replicada entre los servidores que gestionan el dominio. No debe confundirse el Servicio de Directorio que implica la gestión de la base de datos llamada Directorio con el Directorio propiamente dicho.

Los protocolos de acceso a los directorios son protocolos a nivel de aplicación que permiten el acceso a un servicio de directorio.

El protocolo actualmente más utilizado es LDAP (Light Directory Access Protocol)

Originalmente, surgieron algunos servicios de directorio en los años 80 tales como NIS de Sun Microsystems o Banyan VINES o los servicios de directorio de NT de Microsoft.

La ITU e ISO posteriormente crearon X.500 con la intención de normalizar las consultas y estructuras del directorio, así como los protocolos de acceso.

Los sistemas de directorio actuales heredan muchas características de X.500 y de ahí su interés en este capítulo. Los actuales protocolos de acceso usan directamente TCP/IP en vez de toda la pila OSI.

8.1 X.500. Arquitectura y modelo de información.

El servicio de directorio X.500 fue desarrollado inicialmente para la gestión de direcciones de mensajes de correo electrónico en conjunción con la aplicación de correo electrónico X.400, y dado su gran potencial, se segregó como un estándar distinto.

X.500 se define en el **ISO/IEC 9594**

8.1.1 Arquitectura

Cuenta con una arquitectura distribuida elementos que interrelacionan para proporcionar el servicio de directorio.

- **DIT (Directory Information Base).** Es el conjunto de toda la información disponible en el Servicio de Directorio que se organiza de forma jerárquica en forma de árbol.
- **DSA (Directory System Agent):** Los servidores que almacenan los datos de la DIT.

- **DUA (Directory User Agent):** Software instalado en los clientes que permite a los usuarios acceder a las consultas del Directorio. En el caso de que el cliente sea una aplicación en vez de un usuario, la interfaz en vez de ser manual se realizará mediante una API.

8.1.2 Modelo de Información

Veremos ahora la estructura de las entradas del DIB (Directory Information Base).

El DIB tiene una estructura de árbol con una organización jerárquica de entradas que se distribuyen a través de uno o más servidores. Un directorio X.500 está compuesto de entradas que incluyen atributos.

- El DIT (Directory Information Tree) es la estructura del directorio.
- Las entradas son objetos y están compuestas de atributos. Los atributos se definen por su tipo y por los valores que pueden adoptar.

El servicio de directorio nombra las entradas según su posición dentro de la estructura en árbol mediante nombres:

- RDN (Relative Distinguished Name). Nombre por cada nivel del árbol.
- DN (Distinguished Name). Nombre completo que distingue de manera única a cada entrada (parecido a una ruta de acceso a un fichero). Es único por cada entrada del árbol, y está formado por una combinación de su propio RDN, uno o más atributos de la entrada, y los RDN de las entradas superiores hasta la raíz del DIT.

8.1.3 Protocolos

Para comunicarse dos elementos de la arquitectura que residen en sistemas distintos, se precisa del uso de un protocolo.

Los protocolos que se contemplaron inicialmente para X.500 de la UIT-T para Servicios de Directorio definen los siguientes protocolos:

- **DAP (Directory Access Protocol)**, para la comunicación entre DUA y DSA.
- **DSP (Directory System Protocol)**, entre DSAs.
- **DISP (Directory Information Shadowing Protocol)**, replicación entre DSAs.
- **DOP (Directory Operational Bindings Management Protocol)**.

Estos protocolos usaban la torre completa de OSI. Para usar TCP/IP se diseñó LDAP

8.1.4 Relación entre X.500 y los certificados digitales X.509

El estándar X.500 incluía otros para diferentes tareas. Así, por ejemplo, X.520 y X.521 incluían los objetos y sus atributos necesarios para representar a personas y organizaciones como entradas del directorio DIT.

Los certificados de servidor de tipo X.509 que se han visto en el capítulo 5 contienen información relativa a las organizaciones usando el estándar X.500. Así por ejemplo el DN de un certificado X.509 sigue la misma nomenclatura que la propuesta por X.500. Su uso para Internet fuera del estándar OSI

fue debido a la necesidad de la implementación de la autenticación de servidores para implementar protocolos como el SSL/TLS y se usó un estándar ya existente.

8.2 LDAP

LDAP - Lightweight Directory Access Protocol se puede considerar tanto como el protocolo de acceso a un servicio de directorio como a un servicio de directorio en sí mismo, aunque el nombre más apropiado de este último sería LDIF (LDAP Data Interchange Format).

Si en X.500 se usaba el protocolo DAP, que hacía uso de la Pila OSI entera, LDAP es similar, pero usando sólo TCP/IP, de ahí lo de "Lightweight".

En la primera versión, el ámbito del protocolo incluía simplemente navegación en el directorio y funciones de búsqueda, con la versión 2 (LDAPv2) se incorporan más funcionalidades como la de la actualización, pero no permite autenticación ni conexión cifrada, por lo que en la actualidad se desaconseja su uso por motivos de seguridad.

La versión más reciente de LDAP es la v3 que soporta TLS, y está definida en las RFCs siguientes:

RFC 2251 y RFC 2256 (documento base de LDAP), RFC 2829 (método de autenticación para LDAP), RFC 2830 (extensión para TLS), y RFC 3377 (especificación técnica).

OpenLDAP es una **implementación libre del protocolo LDAP**, si bien tiene su propia licencia, la OpenLDAP Public License y soporta múltiples esquemas de Servicios de Directorio a los que interrogar, por lo que lo convierte en muy versátil. Se originó en el año 1993 en la universidad de Michigan.

Versiones propietarias de LDAP bastante conocidas son:

- **Microsoft Active Directory.** El Directorio permite crear un repositorio en el cual almacenar toda la información importante del dominio con una estructura propia bien definida.
- **Red Hat Directory Server.**
- **Apache Directory Server.**
- **Sun One Directory Server.** Anteriormente denominado iPlanet Directory Server.
- **Novell NDS eDirectory.** Servicio de directorio de Novell (muy antiguo ya)

8.2.1 Uso del protocolo: Queries

Para usar este protocolo en Internet se utilizan **queries**.

Las queries que realiza LDAP para interrogar sobre posibles servicios de directorio compatibles localizables en un determinado servidor publicado en Internet siguen el siguiente formato:

ldap://host:port/DN?attributes?scope?filter?extensions

- **host** es el FQDN (Fully Qualified Domain Name) o dirección IP del servidor LDAP donde se realiza la consulta.
- **port** es el puerto de red del servidor LDAP, típicamente el puerto TCP 389 o el 636 si se usa mediante SSL/TLS lo que se indica indicando **ldaps** en vez de ldap en la query correspondiente.
- **DN** (Distinguished Name) es el campo a usar como base de búsqueda (similar a lo visto para X.500).
- **attributes** es una lista separada con comas de atributos que deseamos obtener como respuesta.

- **scope** especifica el ámbito de búsqueda y puede ser "base" (por defecto), "one" o "sub".
- **filter** es un filtro de búsqueda. Por ejemplo (objectClass=*) como es definido en RFC 4515 (para consultas sobre objetos).
- **extensions** son extensiones al formato URL de LDAP.

8.2.2 Modelo de Información

LDAP es definido en términos de ASN.1, y los protocolos del mensaje están codificados en el formato binario BER. Sin embargo, utiliza representaciones textuales para un número de campos y tipos ASN.1

Típicamente, los campos que suele contener y que se pueden intercambiar con otras aplicaciones (formato LDIF) son:

- **DN** (Distinguished Name) (similar a lo referido para X.500).
- **DC** (Domain Component), se refiere a cada componente del dominio. Por ejemplo la cadena entera del dominio www.google.com se puede referir con tres DC: DC=www, DC=google, DC=com
- **OU** (Organizational Unit), se refiere a la organización o al grupo del usuario, si el usuario está incluido en alguno específico. Si el usuario está en más de un grupo, se especificarán todos, por ejemplo, OU=Unidad Jurídica, OU=Abogado.
- **CN** (Common Name), se refiere al objeto que referencia al individuo, por ejemplo, nombre, despacho, denominación del puesto de trabajo, etc.

8.2.3 Arquitectura

La arquitectura presenta tres componentes:

- SLAPD (para standalone) y SLURPD (para versión distribuida): Demonio residente en el servidor/servidores y herramientas
- Base de datos del directorio y Bibliotecas de implementación del modelo ASN.1, usando LDIF y hace años usando bases de datos de backend
- Programas cliente de acceso al servidor: Idapsearch, Idapadd, Idapdelete
- Overlays, para comunicación entre los servidores de frontend y los de backend que contienen la base de datos del Directorio.

La siguiente tabla resume el conjunto de funciones que implementa LDAP:

<u>Consulta</u>	Permiten realizar búsquedas y lecturas de datos	• Search: buscar y obtener entradas de directorio • Compare: probar si una entrada nombrada contiene un valor de atributo dado
<u>Modificación</u>	Permite añadir, borrar renombrar y modificar entradas del directorio	• Add: permite añadir nuevas entradas al directorio. • Delete: permite eliminar entradas del directorio. • Modify: modificar una entrada • Modify Distinguished Name (DN): modificar o renombrar una entrada
<u>Autenticación y control</u>	Permiten la identificación de los clientes e iniciar una sesión	• Bind: permite autenticar al cliente frente al directorio (tres tipos de autenticación: anónima, autenticada y cifrada) • Unbind: cierra conexión con el LDAP. • Abandon: aborta la operación en curso.

Tabla 1: Funciones de Idap

RESUMEN ESQUEMÁTICO

- La verificación de la identidad tanto de ciudadanos como de sitios web de la Administración es fundamental para generar confianza en el uso de los servicios electrónicos que ésta presta.
- La gestión de la identidad comprende los siguientes pasos: Identificación, Autenticación, Autorización y Auditoría.
- La identificación de los interesados en el Procedimiento Administrativo Común está regulada en el artículo 9 de la Ley 39/2015. La identificación de las Administraciones Públicas está regulada en el artículo 40 de la Ley 40/2015.
- El Esquema Nacional de Seguridad establece requisitos de acceso (Anexo II, controles “op.acc”) según la categoría del sistema y en relación función de los mecanismos implementados para acceder a los sistemas.
- La firma electrónica implica el consentimiento por vía electrónica del implicado/implicados (puede ser que haya que firmar varios) en el procedimiento en cuestión y se consigna de forma digital en el documento electrónico correspondiente. Las garantías de la firma en un procedimiento administrativo están avaladas por la Ley 59/2003, Ley de Firma Electrónica.
- En qué situaciones se requerirá la firma dentro de un procedimiento administrativo común está recogido en el artículo 11.2 de la ley 39/2015.
- La firma de un documento electrónico puede que precise ser realizada por varios individuos. Si todos tienen la misma importancia se habla de co-firma y si unos tienen que refrendar a otros y la firma se hace en cascada hablamos de contrafirma, lo que a menudo se resuelve usando un Portafirmas.
- El eIDAS es el Reglamento Europeo 910/2014 que introduce novedades tales como la desaparición de los certificados de persona jurídica o de colectivos, todos los certificados identificativos deberán estar asignados a personas físicas. No deroga la ley de Firma, pero sí que prevalece sobre aquella en lo que pueda existir controversia
- A nivel nacional, además de la Ley de Firma Electrónica aplican a la Administración El Esquema Nacional de Interoperabilidad, que en su capítulo IX establece las condiciones de interoperabilidad relativas a la firma electrónica y sus certificados electrónicos, la Norma Técnica de Interoperabilidad y para el ámbito de la AGE, la Política de Firma Electrónica
- Un certificado X.509v3 es un certificado electrónico que sirve para acreditar la identidad de sitios web. Deben estar avalados por una Autoridad de Certificación. Los certificados de este tipo deben cumplir una serie de garantías para que el navegador los marque como confiables para el usuario. Estos certificados permiten la conexión mediante SSL/TSL del cliente.
- El uso de claves concertadas está permitido para ciertos procedimientos administrativos en función de su categorización de acuerdo con el ENS. Para automatizar este uso existe Cl@ve que permite el acceso a múltiples servicios con un único registro del usuario, mediante usuario y contraseña. Esta contraseña puede ser temporal y de un solo uso o permanente, cada tipo requerirá de un registro determinado para obtener las credenciales.
- Los formatos de firma nos sirven guardar los documentos firmados con garantías de interoperabilidad posterior y para añadir funcionalidades que doten a la firma de capacidades deseables, tales como la verificación posterior de lo firmado pasado un tiempo corto o muy largo (firmas longevas).
- Los Servicios de Directorio permiten automatizar la gestión de usuarios en los sistemas ya que contienen información relativa a dichos usuarios que se usa para los controles de la identidad y permisos. Para acceder a dichos servicios se usan protocolos.
- X.500 es el protocolo más antiguo para acceder a Servicios de Directorio, pero es la base que da lugar a protocolos más modernos como LDAP, que utiliza TCP/IP en vez de la pila OSI de X.500.

PREGUNTAS DE TEST

- 1) El servicio REN0 de la Agencia Tributaria te permite acceder a la gestión de la Renta del año en cuestión. Para ello te pide una serie de datos tales como el DNI, alguna casilla de la declaración de la renta del año anterior y un teléfono para enviarte un SMS con una referencia, que después te pedirá para poder acceder finalmente a la gestión en cuestión. Esta referencia enviada al se puede considerar que es:
 - a) La identificación del contribuyente.
 - b) El único factor de autenticación del contribuyente.
 - c) Un sistema de firma electrónica reconocida.
 - d) Un segundo factor de autenticación.
- 2) Si necesito presentar en papel un documento firmado electrónicamente, ¿es correcto imprimir dicho documento y presentarlo donde sea oportuno?
 - a) Sí, porque en el documento en papel aparecen consignados los datos de firma y se pueden apreciar claramente.
 - b) No, porque la firma electrónica es sólo para documentos electrónicos. Si quiero demostrar la validez de una impresión sobre un documento electrónico firmado electrónicamente, el documento impreso debe contener un mecanismo de validación CSV como por ejemplo usar un CVE.
 - c) No, porque la firma electrónica es sólo para documentos electrónicos. Si quiero presentarlo luego en papel tendré que firmarlo manuscritamente encima.
 - d) Sí, siempre que al imprimir en papel añada el logotipo del organismo que lo emite que funciona como un sello.
- 3) La diferencia fundamental entre la co-firma y la contrafirma es que:
 - a) En la co-firma todas las firmas tienen el mismo peso en el documento y, por tanto, da igual en qué orden firmen los firmantes y en la contrafirma los firmantes tienen unos más relevancias que otros por lo que la firma se va haciendo secuencialmente siendo el último que firme el que más peso tiene en el documento que se firma.
 - b) La co-firma necesita de un PortaFirmas y la contrafirma no lo usa nunca.
 - c) La co-firma es sólo cuando firman dos personas y la contrafirman cuando firman tres o más personas.
 - d) La co-firma es en cascada con cada siguiente firmante de más relevancia y la contrafirma es cuando todos los firmantes tienen el mismo peso y da igual el orden de la firma.
- 4) Si tengo un certificado de persona jurídica, a partir del 1 de julio del 2016 ha ocurrido que:
 - a) Ya no he podido utilizarlo más.
 - b) Me han enviado un aviso de que tengo que cambiarlo por un certificado de administrador solidario o absoluto.
 - c) No he podido renovarlo, aunque sí utilizarlo hasta su caducidad (o revocación).
 - d) Me lo han revocado de forma automática.
- 5) ¿Qué es una CA raíz?
 - a) Un certificado X.509v3 autofirmado.
 - b) Una CA que avala un certificado X.509v3
 - c) Una CA que avala todos los certificados X.509v3 que hay en Internet.
 - d) Una CA que es el nodo raíz de una jerarquía de Autoridades de Certificación y, por tanto, su certificado se instala autofirmado y se preinstala en el navegador.

- 6) Si estoy usando Cl@ve en modo temporal (similar a PIN24h) y cierro el navegador (o me desconecto de la sede electrónica), me voy al baño y vuelvo pasados 7 minutos ocurrirá que:
- a) Podré volver a utilizar las credenciales siempre que siga trabajando en el mismo procedimiento administrativo y sitio web.
 - b) No podré volver a utilizar las credenciales porque he cerrado el navegador (o me he desconectado).
 - c) Podré volver a utilizar las credenciales siempre que siga trabajando en el mismo procedimiento administrativo y sitio web porque no han pasado los 10 minutos que dura la clave.
 - d) Podré volver a utilizar las credenciales, pero en otro procedimiento administrativo porque en el anterior ya han caducado.
- 7) Si quiero conservar un documento firmado en formato pdf para garantizar que será válido dentro de 20 años deberé utilizar el siguiente formato de firma:
- a) PAdES-T
 - b) CAdES-XL
 - c) PAdES-XL
 - d) XAdES-XLCA
- 8) En el proceso de firma se cumple que:
- a) Se firma con la clave pública de firma del destinatario y se descifra con la clave privada de firma del firmante.
 - b) Se firma con la clave privada de firma del remitente y el destinatario la descifra con su propia clave pública de firma.
 - c) Se firma con la clave privada de firma del remitente y el destinatario la descifra con la clave pública de firma del remitente.
 - d) Se intercambian primero las claves privadas de cifrado para garantizar la confidencialidad de lo firmado y luego realizan una cofirma para poder acceder al documento firmado tanto destinatario como remitente.
- 9) La diferencia esencial entre Marca de Tiempo y Sello de Tiempo es que:
- a) El Sello de Tiempo lo proporciona siempre una Autoridad de Sellado de Tiempo (TSA) que da fe de que esa es la hora en la que realizó el trámite mientras que la Marca de Tiempo la puede proporcionar el propio sistema y puede haberse manipulado.
 - b) La Marca de Tiempo no es exacta y la de Sello sí que refleja la hora del Real Observatorio de San Fernando.
 - c) El Sello de Tiempo marca la fecha y hora con un sello de homologación en lugar visible.
 - d) El Sello de Tiempo lo firma una Autoridad Horaria Competente que está en Internet.
- 10) El protocolo LDAP frente al DAP de X.500 tiene la siguiente diferencia notable:
- a) No usa el campo DN y en su lugar usa una variante de DNS.
 - b) Usa TCP/IP en vez de toda la pila OSI.
 - c) Usa el puerto TCP 329 en vez del 500 que usa X.500.
 - d) No tiene estructura de árbol sino de base de datos relacional.

SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	d
2	b
3	a
4	c
5	d
6	b
7	c
8	c
9	a
10	b

BIBLIOGRAFÍA BÁSICA

1. <https://www.boe.es/buscar/act.php?id=BOE-A-2015-10565&p=20151002&tn=2> Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas.
2. <https://www.boe.es/buscar/act.php?id=BOE-A-2015-10566&p=20151002&tn=2> Ley 40/2015 de 1 de octubre, de Régimen Jurídico del Sector Público.
3. http://www.boe.es/diario_boe/txt.php?id=BOE-A-2015-11881 Real Decreto 951/2015, de 23 de octubre, de modificación del Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.
4. <https://www.boe.es/buscar/act.php?id=BOE-A-2003-23399> Ley 59/2003 de 19 de diciembre, de Firma Electrónica.
5. <http://firmaelectronica.gob.es/Home/Ciudadanos/Formatos-Firma.html> Portal de Firma Electrónica.
6. <http://eur-lex.europa.eu/legal-content/ES/TXT/HTML/?uri=CELEX:32014R0910&from=EN> Reglamento europeo 910/2014 sobre Identificación Electrónica y Servicios de Confianza.
7. <https://www.boe.es/doue/2015/235/L00007-00020.pdf> Reglamento de Ejecución 2015/1502
8. <https://www.boe.es/buscar/act.php?id=BOE-A-2010-1331> Real Decreto 4/2010 de 8 de enero, por el que se regula el Esquema Nacional de Interoperabilidad en el ámbito de la Administración Electrónica.
9. <http://www.minetad.gob.es/telecomunicaciones/es-ES/Participacion/Paginas/Cerradas/servicios-electronicos-confianza.aspx>
Borrador del anteproyecto de la Ley de Servicios de Confianza.
10. https://sede.administracion.gob.es/PAG_Sede/LaSedePAG/PoliticaFirmaElectronicaYCertificadosAGE.html Política de Firma Electrónica de la AGE.
11. https://administracionelectronica.gob.es/pae_Home/pae_Estrategias/pae_Interoperabilidad_Inicio/pae_Normas_tecnicas_de_interoperabilidad.html#POLITICAFIRMA Norma Técnica de Interoperabilidad.
12. http://clave.gob.es/clave_Home/clave.html Portal de información sobre Cl@ve.

BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

13. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/543-ccn-stic-825-ens-iso27001/file.html> Esquema Nacional de Seguridad. Certificaciones 27001
14. <https://www.rediris.es/ldap/doc/ldap-intro.pdf> Red Iris, introducción a los servicios de directorio.
15. <https://www.rediris.es/gt/gt2016/programa/fid/MINHAP-eIDAS.pdf> DTIC (actual SGAD), III Foro de Identidad Red IRIS 2 de junio del 2016.
16. <https://www.boe.es/doue/2015/235/L00037-00041.pdf> Decisión de Ejecución (UE) 2015/1506.